

ICS410

模試 2

Question 1 of 82

What guideline should be followed when setting up a secure ICS network architecture?

- ☐ Internet access should not go deeper than level 3 (Site-Wide Supervisory)
- ☐ Require traffic between the business and control networks to stop at a server in the DMZ
- ☐ Place patch management servers for the control networks in the ICS DMZ
- ☐ Enterprise Active Directory should not extend to level 4 (Business Network)

全82問中1問目

安全なICSネットワークアーキテクチャを構築する際に、どのようなガイドラインに従うべきでしょうか？

- ☐ インターネットアクセスはレベル3（サイト全体の監視）より深いレベルまで到達させてはならない。
- ☒ **ビジネスネットワークと制御ネットワーク間のトラフィックをDMZ内のサーバーで停止させるようにする。**
- ☐ 制御ネットワーク用のパッチ管理サーバーをICS DMZに配置する
- ☐ エンタープライズActive Directoryはレベル4（ビジネスネットワーク）まで拡張すべきではありません。

☒ その通りです

安全なICSネットワークを構築するための推奨サイバーセキュリティガイドラインには、次のものが含まれます。1) インターネットアクセスと電子メールがレベル4より深く進まないこと、2) エンタープライズActive Directoryをレベル4より下に拡張しないこと、3) ビジネスネットワークと制御ネットワーク間のすべてのトラフィックがICS DMZ内のサーバーで停止するようにすること、4) 制御ネットワークのパッチ管理サーバーをパデューレベル3に配置すること。

Question 2 of 82

How are Microsoft security templates stored?

- ☐ Base64 encoded
- ☐ Plaintext file
- ☐ XML file
- ☐ Proprietary format based on JSON

全82問中2問目

Microsoftのセキュリティテンプレートはどのように保存されますか？

- ☐ Base64エンコード
- ☒ プレーンテキストファイル
- ☐ XMLファイル
- ☐ JSONに基づいた独自のフォーマット

✓ その通りです

Microsoft セキュリティ テンプレートは、数百ものセキュリティ設定を保存できるプレーンテキスト構成ファイルです。メモ帳などのテキストエディタで手動で編集することもできますが、MMC スナップインの「セキュリティ テンプレート」を使用する方がはるかに安全で簡単です。

Question 3 of 82

Which type of ICS component uses the fastest polling rate?

- ☐ Regional SCADA
- ☐ Engineering workstation
- ☐ Programmable logic controller
- ☐ Site SCADA

全82問中3問目

ICSコンポーネントの中で、最も高速なポーリングレートを使用するのはどのタイプですか？

- ☐ 地域SCADA
- ☐ エンジニアリングワークステーション
- ☒ プログラマブルロジックコントローラ
- ☐ サイトSCADA

☒ その通りです

ポーリングレートは、さまざまな種類のICSコンポーネントを区別するのに役立ちます。地域SCADAは数秒から数分と最も長いポーリングレートを持ち、一方、コントローラやフィールドデバイスは1秒未満のタイミングで計測するため、最も短いポーリングレートになります。

Question 4 of 82

An exploitable vulnerability is discovered in a vendor's controller software. Which artifact would a security analyst look up, using a unique identifier assigned to the vulnerability, in order to read more detailed information about the identified issue?

- ☐ CVSS
- ☐ TTP
- ☐ CWE
- ☐ CVE

全82問中4問目

ベンダーのコントローラーソフトウェアに悪用可能な脆弱性が発見されました。セキュリティアナリストは、脆弱性に割り当てられた固有の識別子を使用して、特定された問題に関するより詳細な情報を読み取るために、どのアーティファクトを検索するでしょうか？

- ☐ CVSS
- ☐ TTP
- ☐ CWE
- ☒ **CVE**

✔ その通りです

特定のシステムにおける特定の脆弱性は、CVE固有のIDによって識別されます。

CVSSとは共通脆弱性評価システムの略で、脆弱性の深刻度を数値で表すための枠組みです。

CWEとは共通脆弱性列挙の略で、特定の脆弱性ではなく、高レベルの脆弱性に焦点を当てたものです。

TTPとは、戦術、技術、手順のことです。

Question 5 of 82

An attack that modifies data in an ICS is a violation of which information security concept?

- ☐ Confidentiality
- ☐ Availability
- ☐ Non-repudiation
- ☐ Integrity

全82問中5問目

ICS内のデータを改ざんする攻撃は、どの情報セキュリティ概念に違反するでしょうか？

- ☐ 機密保持
- ☐ 可用性
- ☐ 否認禁止
- ☒ 誠実さ

☒ その通りです

完全性制御は情報の改ざんを防止するため、予期せずデータを変更できる攻撃は完全性に対する攻撃となります。機密性とは、権限のある者のみがデータにアクセスできるようにすることです。可用性とは、必要なときにデータにアクセスできることを意味します。否認防止とは、ある人物が何らかの行動をとったことを否定できないようにすることです。

Question 6 of 82

Which of the following describes an effective policy?

- ☐ Achievable and measurable directive
- ☐ Organizational values statement
- ☐ Best practice based instruction
- ☐ Risk and compliance based guidance

全82問中6問目

次のうち、効果的な政策を説明しているのはどれですか？

- 597103981bec-4178-9e4b-ad14107359a6 (14232745)
- ☒ **達成可能かつ測定可能な指示**
 - ☐ 組織の価値観に関する声明
 - ☒ **ベストプラクティスに基づいた指導**
 - ☐ リスクとコンプライアンスに基づくガイダンス

☒ **あなたは間違っています**

政策とは、特定の目標に向かって進むための明確な決定を示す指示である。政策自体は効果的かつ現実的であり、達成可能な安全保障目標を持つべきである。

Question 7 of 82

What is being determined when multiplying an asset value to the exposure factor (EF) percentage?

- ☐ Annualized rate occurrence
- ☐ Single loss expectancy
- ☐ NERC CIP fine
- ☐ Annualized loss expectancy

全82問中7問目

資産価値にエクスポージャー係数（EF）のパーセンテージを乗じることで、何が決定されるのでしょうか？

- ☐ 年間発生率
- ☒ 単一損失期待値
- ☐ NERC CIP罰金
- ☐ 年間損失期待値

☒ その通りです

SLEは、単一の事象に割り当てられる金額です。つまり、単一の事象によって組織が被る損失額です。エクスポージャーファクター（EF）は、脅威事象が資産に及ぼす損失の割合です。EFは、資産の損失率0～100%で表されます。その計算式は次のとおりです。単一損失期待値（SLE）＝資産価値×損失率（EF）

Question 8 of 82

Which of the following is part of the Protect function of the NIST CSF (cybersecurity framework)?

- ☐ Containing an event and eradicating it from the network
- ☐ Establishing security policies and personnel responsibilities
- ☐ Providing awareness training for organizational personnel and partners
- ☐ Monitoring the network for malicious activity

全82問中8問目

NIST CSF（サイバーセキュリティフレームワーク）の保護機能に含まれるものはどれですか？

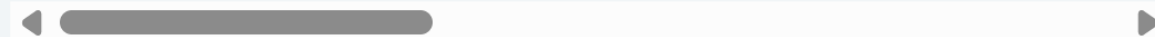
- ☐ イベントを封じ込め、ネットワークから排除する
- ☐ セキュリティポリシーと担当者の責任を確立する
- ☒ 組織の職員およびパートナー向けに意識向上トレーニングを提供する
- ☐ 悪意のある活動がないかネットワークを監視する

✔ その通りです

組織の従業員およびパートナーに対し、サイバーセキュリティ意識向上トレーニングを提供することは、保護機能の一部です。セキュリティポリシーの策定、従業員の役割と責任の明確化は、識別機能に該当します。検出機能の目的の一つは、ネットワーク上の悪意のある活動を監視することです。事象の拡散を防ぎ、ネットワークから排除する緩和策は、対応機能の一部です。

NIST CSF Protect (PR) 機能より:

意識向上とトレーニング（PR.AT）：組織の職員およびパートナーは、サイバーセキュリ:



セキュリティ ポリシーと担当者の責任を確立することは、ID 機能 (ID)、**ID.GV**の一部です。

ネットワークの監視は、検出（DE）機能、**DE.CM**の一部です。

封じ込めと根絶は、回復（RC）機能、**RC.RP**の一部です。

Question 9 of 82

If an asset has an SLE of \$36,000 and an ALE of \$144,000 what is the applicable ARO?

- ☐ \$108,000
- ☐ \$180,000
- ☐ 4
- ☐ 1/4

全82問中9問目

資産のSLEが36,000ドル、ALEが144,000ドルの場合、適用されるAROはいくらですか？

☒ 10万8000ドル

☐ 18万ドル

☒ 4

☐ 1/4

☒ あなたは間違っています

$$\text{ALE} = \text{SLE} * \text{ARO}$$

$$\$144,000 = \$36,000 * \text{ARO}$$

$$\text{ARO} = \$144,000 / \$36,000$$

$$\text{ARO} = 4$$

Question 10 of 82

What information is found in the output of the following command?

```
[tech@archlinux ~]$ df -h
```

Filesystem	Size	Used	Avail	Use%	Mounted on
dev	1.9G	0	1.9G	0%	/dev
run	1.9G	1.6M	1.9G	1%	/run
/dev/sda1	20G	13G	5.9G	69%	/
tmpfs	1.9G	0	1.9G	0%	/dev/shm
tmpfs	1.9G	36K	1.9G	1%	/tmp
tmpfs	390M	88K	389M	1%	/run/user/1000

- ☐ Frequency of use for mounted filesystems
- ☐ Most recently mounted filesystems
- ☐ Filesystem types of mounted partitions
- ☒ **Disk space utilized by mounted partitions**

全82問中10問目

次のコマンドの出力にはどのような情報が含まれていますか？

```
[tech@archlinux ~]$ df -h
```

Filesystem	Size	Used	Avail	Use%	Mounted on
dev	1.9G	0	1.9G	0%	/dev
run	1.9G	1.6M	1.9G	1%	/run
/dev/sda1	20G	13G	5.9G	69%	/
tmpfs	1.9G	0	1.9G	0%	/dev/shm
tmpfs	1.9G	36K	1.9G	1%	/tmp
tmpfs	390M	88K	389M	1%	/run/user/1000

- ☐ マウントされたファイルシステムの使用頻度
- ☐ 最近マウントされたファイルシステム
- ☐ マウントされたパーティションのファイルシステムの種類
- ☒ マウントされたパーティションによって使用されるディスク容量

✓ その通りです

ここに表示されている出力は、dfLinuxシステム上の`disk free`コマンドの出力です。このコマンドは、ディスクまたはディスクセット上のパーティションの数、名前、サイズ、および使用率を表示するために使用されます。

Question 11 of 82

What is described below?

An unmanned surface vehicle (USV) is supposed to travel at 30 knots.
If the velocity is 15 kn or less, the throttle is set to 100%.
If the velocity is between 15 kn and 20 kn the throttle is set to 75%.
If the velocity is between 20 kn and 25 kn the throttle is set to 50%.
If the velocity is between 25 kn and 30 kn the throttle is set to 25%.

- ☐ Sequential function block
- ☐ Fuzzy logic
- ☐ Ladder logic
- ☐ Instruction list
- ☐ PID loop

以下に説明されている内容は何ですか？

An unmanned surface vehicle (USV) is supposed to travel at 30 knots.

If the velocity is 15 kn or less, the throttle is set to 100%.

If the velocity is between 15 kn and 20 kn the throttle is set to 75%.

If the velocity is between 20 kn and 25 kn the throttle is set to 50%

If the velocity is between 25 kn and 30 kn the throttle is set to 25%.

- ☐ シーケンシャルファンクションブロック
- ☒ ファジーロジック
- ☐ ラダーロジック
- ☐ 手順一覧
- ☐ PIDループ

× あなたは間違っています

ファジー論理は「真偽の度合い」に関係します。USVが30ノットを超えて移動している場合、それは速すぎる速度で移動していますが、論理式で単にyesまたはno,1または0を使用した場合、「どれくらい」速すぎるかはわかりません。31ノットでの移動も速すぎますし、70ノットでの移動も速すぎますが、これらの状態それぞれに対して異なる対応が必要になる場合があります。この論理式は、人が読みやすく、システムが何をすべきかを簡単に識別できます。これらの論理式は、数学的評価のためにファジー論理に変換されます。

ラダーロジックと命令リストは、プログラミング言語の一種である。

Question 12 of 82

What is an advantage of using virtualization in an ICS environment?

- ☐ Simplifies troubleshooting and monitoring
- ☐ Makes system patching and backups easier
- ☐ Works well across different trust zones on a single host
- ☐ May be safely managed from any zone in the organization

全82問中12問目

ICS環境において仮想化を利用する利点は何ですか？

- ☒ **トラブルシューティングと監視を簡素化します**
- ☒ **システムのパッチ適用とバックアップが容易になります**
- ☐ 単一ホスト上の異なる信頼ゾーン間でも正常に動作します
- ☐ 組織内のどのゾーンからでも安全に管理できます

☒ **あなたは間違っています**

ICS環境における仮想化の利点としては、リソースの統合、冗長性、テストおよびトレーニング環境の構築、パッチ適用とバックアップの管理の容易化などが挙げられます。仮想化は、同一ホスト上の異なる信頼ゾーンにまたがって構築すべきではありません。信頼ゾーンからのみ管理されるべきです。場合によっては、仮想化によってトラブルシューティングやシステム監視の複雑さが増すこともあります。

Question 13 of 82

What is the function of a safety system (for example an SIS integrated into a plant's DCS)?

- ☐ Sets standards for plant personnel to safeguard themselves from injury
- ☐ Open interlocks on command
- ☐ Provide predictable and timely fail-safe shutdown of the process
- ☐ Provide the control for hazardous materials in a process
- ☐ Identify plant personnel locations during an emergency

全82問中13問目

安全システム（例えば、プラントのDCSに統合されたSIS）の機能は何ですか？

- ☒ 工場従業員が怪我をしないようにするための基準を設定する。
- ☐ 指示に応じてインターロックを開放する
- ☒ プロセスの予測可能かつタイムリーなフェイルセーフシャットダウンを提供する
- ☐ プロセスにおける危険物質の管理を提供する
- ☐ 緊急時に工場職員の所在を確認する

✕ あなたは間違っています

安全システムの機能は、事前に定義された安全状態／事象が発生した場合に、人員、環境、設備、および制御システムを保護するために、ICSアプリケーションとプロセスを予測可能かつタイムリーにフェイルセーフシャットダウンすることです。安全システムは専用の目的を果たし、この種の産業制御システムを必要とするプロセスにとって不可欠な機能です。安全システムは人員の位置を特定する役割を担うものではなく、人員の安全に関する管理基準を設定するためにも使用されません。安全システムはプロセスの主要な制御を行うものではなく、常に監視を行い、危険な状態が発生した場合に備えて待機しています。最後に、インターロックを開くのは、いずれのシステムにも属さない機能です。

Question 14 of 82

What is a recommended guideline to follow when setting up a secure ICS network architecture?

- ☐ Move any onsite servers that communicate with the cloud for control systems to the ICS DMZ
- ☒ **Do not set up a trust between Active Directory domains on the control network and the Enterprise network**
- ☐ Use the same jump hosts for employees and vendors
- ☐ Place simple proxies in the ICS DMZ to keep them separate from systems in the control network

全82問中14問目

安全なICSネットワークアーキテクチャを構築する際に推奨されるガイドラインは何ですか？

- ☐ 制御システムのためにクラウドと通信するオンプレミスサーバーをすべてICS DMZに移動してください。
- ☒ **コントロールネットワークとエンタープライズネットワーク上のActive Directoryドメイン間で信頼関係を構築しないでください。**
- ☐ 従業員とベンダーには同じジャンプホストを使用する
- ☐ シンプルなプロキシをICS DMZに配置して、制御ネットワーク内のシステムから分離します。

☒ その通りです

安全なICSネットワークアーキテクチャを構築するための推奨サイバーセキュリティガイドラインには、次のものが含まれます。1) 単純なプロキシは脆弱性を盲目的に通過させるため使用を避ける、2) エンタープライズとの信頼関係を持たない制御ネットワーク用の別のADドメインを設定する、3) 制御ネットワークのクラウドに接続するオンサイトサーバーをICS DMZに配置せず、別のDMZに配置する、4) リモートで制御ネットワークにアクセスする各従業員またはベンダーは、それぞれのニーズに応じて異なるジャンプホストを使用する。

Question 15 of 82

What is the Annualized Loss Expectancy (ALE) for a \$300,000 asset with an exposure factor of 25% and an Annualized Rate Occurrence of 6?



\$200,000



\$50,000



\$75,000



\$450,000

全82問中15問目

エクスポージャー係数が25%、年間発生率が6の30万ドルの資産に対する年間損失期待値（ALE）はいくらですか？

☒ 20万ドル

☐ 5万ドル

☐ 75,000ドル

☒ 45万ドル

☒ あなたは間違っています

$$\text{ALE} = \text{AV} * \text{EF} * \text{ARO}$$

$$\text{ALE} = \$300,000 * 25\% * 6$$

$$\text{ALE} = \$75,000 * 6$$

$$\text{ARO} = \$450,000$$

Question 16 of 82

Maintaining the temperature within a specific range while producing chemicals or plastics is an example of which type of ICS process model?

- ☐ Discrete
- ☐ Continuous
- ☐ Batch

全82問中16問目

化学薬品やプラスチックを製造する際に、温度を特定の範囲内に維持することは、どのタイプのICSプロセスモデルの例でしょうか？

- ☐ 離散
- ☒ 連続
- ☐ バッチ

✓ その通りです

ICSの主なプロセスモデルは、離散型、バッチ型、連続型、ハイブリッド型の4つです。離散型モデルでは、指定された量の材料がワークステーション間を単位として移動し、各単位はプロセス全体を通して固有の識別情報を保持します。その一例として、金属プレス加工（ナンバープレート）が挙げられます。バッチ処理では、特定の量の原材料が特定の方法で一定期間混合され、中間製品または最終製品が生成されます。その一例として、接着剤や糊の製造が挙げられます。連続型モデルでは、温度などの変数が一定期間、特定の範囲（一定）に維持されます。このタイプの処理の例としては、化学薬品やプラスチックの製造が挙げられます。

Question 17 of 82

An attacker inputs the data shown below on a web-based HMI. What type of attack are they attempting?

```
<script src="eviltest1.js"></script>
```

- ☐ XSS
- ☐ SQLi
- ☐ CSRF
- ☐ LFI

全82問中17問目

攻撃者がウェブベースのHMIに以下のデータを入力します。攻撃者はどのような種類の攻撃を試みているのでしょうか？

```
<script src="eviltest1.js"></script
```



XSS



SQLインジェクション



CSRF



LFI



その通りです

これはクロスサイトスクリプティング（XSS）攻撃の一例です。開発者がユーザー入力を適切に処理せず、文字数を制限したり、出力をエンコードしてからページに再表示したりしない場合、攻撃者は入力にJavaScriptを追加して、ユーザーのブラウザで実行させることができます。この例では、攻撃者はブラウザにJavaScriptプログラムを実行させようとしています `eviltest.js`。

Question 18 of 82

In what way does EtherNet/IP make use of broadcast UDP messages?

- ☐ To provide device authentication
- ☐ To send PLC commands through a router hop
- ☐ To communicate I/O data
- ☐ To manage HMI workstations

全82問中18問目

EtherNet/IPは、ブロードキャストUDPメッセージをどのように利用しているのでしょうか？

- 5971b396-fbec-4178-9c4b-ad14167339a6 (14232745)
- ☒ デバイス認証を提供する
 - ☐ ルーターホップを介してPLCコマンドを送信する
 - ☒ 入出力データを通信するため
 - ☐ HMIワークステーションを管理する

✕ あなたは間違っています

EtherNet/IPは、I/OデータにUDPブロードキャストメッセージを使用します。ブロードキャストは、必要なメッセージ数によっては、ネットワーク上のデバイスに過負荷をかける可能性があります。ネットワークに複数のデバイスが接続されている場合は、マネージドスイッチでIGMPスヌーピングを行うことで、この問題を軽減できます。これはI/Oトラフィックに関する問題であり、ワークステーション/サーバーレベルでは問題になりません。

Question 19 of 82

Who has the ultimate responsibility to ensure an ICS meets security requirements in the field?

- ☐ Government entities
- ☐ Integrators
- ☐ Asset owners
- ☐ Vendor partners

全82問中19問目

現場においてICSがセキュリティ要件を満たしていることを保証する最終的な責任は誰にあるのでしょうか？

- ☐ 政府機関
- ☐ インテグレーター
- ☒ 資産所有者
- ☐ ベンダーパートナー

☒ その通りです

資産所有者／運用者は、効率的で政府規制に適合するシステムを設計・構築するために、ベンダーやシステムインテグレーターと協力する必要があります。近年、セキュリティは世間の注目を集めるようになり、政府規制当局による監視も強化されています。現在、資産所有者／運用者は、運用するシステムにセキュリティが組み込まれるようにする責任を負っています。

Question 20 of 82

Which is a characteristic of a Quantitative risk assessment that is not used in a Qualitative risk assessment?

- ☐ Loss computation
- ☐ Determination of threat impact
- ☐ Assessment of threat risk rating
- ☐ Vulnerability assessment

全82問中20問目

定量的リスク評価の特徴のうち、定性的リスク評価では用いられないものはどれですか？

5971b390-1b2c-4178-9e4b-ad14167339a6 (14232745)



損失計算



脅威の影響の判定



脅威リスク評価



脆弱性評価



その通りです

定量化は、定量的リスク評価と定性的リスク評価の決定的な違いです。損失計算は一般的な定量化手法ですが、制御コストや脅威発生確率の計算なども定量的評価で用いられることがあります。その他の回答はどちらの評価方法でも使用されますが、定性的評価では数値ではなく、高／中／低といった主観的な評価に依拠します。

Question 21 of 82

A penetration tester discovers an open port tcp/23 on a legacy RTU device. What is the most likely attack for the pen tester to attempt?

- ☐ Performing a DoS attack of the RTU over the unauthenticated administration protocol
- ☒ **Sniffing or capturing clear text data and access credentials sent to or from the RTU**
- ☐ Wireless access to the RTU device from a nearby parking lot
- ☐ Accessing the RTU device externally over a dial-up modem

全82問中21問目

侵入テスト担当者が、旧式のRTUデバイス上でTCP/23ポートが開いていることを発見しました。侵入テスト担当者が試みる可能性が最も高い攻撃は何でしょうか？

- ☐ 認証されていない管理プロトコルを介してRTUに対するDoS攻撃を実行する
- ☒ **RTUとの間で送受信される平文データやアクセス認証情報を傍受または傍受する**
- ☐ 近くの駐車場からRTUデバイスへの無線アクセス
- ☐ ダイヤルアップモデム経由でRTUデバイスに外部からアクセスする

☒ その通りです

Telnet（TCP/23ポート）は、パスワードを含むすべてのTelnetトラフィックが暗号化されていないため、深刻なセキュリティリスクであり、攻撃者がデバイスをかなり制御できるようになる可能性があります。

Telnetは認証をサポートしており、Telnetが存在するからといって、デバイスへの無線アクセスやモデムアクセスが可能であることを示すものではありません。

Question 22 of 82

Which of the following is the NTP hierarchical level where an atomic clock is found?

- ☐ Layer 1
- ☐ Layer 7
- ☐ Stratum 0
- ☐ Stratum 15

全82問中22問目

次のうち、原子時計が配置されているNTP階層レベルはどれですか？

- ☐ レイヤー1
- ☐ レイヤー7
- ☒ 層0
- ☐ 第15層

✓ その通りです

ストラタム0は、セシウムやルビジウムを用いた原子時計、GPS時計、その他の電波時計など、高精度な時刻計測装置を指します。これらは「基準時計」と呼ばれます。米国海軍天文台は、米国政府の用途向けに基準時刻信号を維持管理している組織の一例です。

Question 23 of 82

Please examine the risk analysis values noted below. What is the calculated Annualized Loss Expectancy for the particular risk?

- **ASSET VALUE: \$100**
- **SINGLE LOSS EXPECTANCY: \$60**
- **LIKELIHOOD: 0.15**
- **FREQUENCY: 5**

☐ \$45

☐ \$75

☐ \$300

☐ \$15

全82問中23問目

下記のリスク分析値をご確認ください。当該リスクに対する年間損失期待値はいくらですか？

- 資産価値：100ドル
- 1回の損失予想額：60ドル
- 可能性: 0.15
- 頻度：5

☒ 45ドル

☒ 75ドル

☐ 300ドル

☐ 15ドル

☒ あなたは間違っています

年間損失期待値とは、特定の脅威によって生じる年間予想財務損失額のことです。この値は、3つの異なる計算によって算出されます。

- 単一損失期待値 = 資産価値 × 損失率
- 年間発生率 = 可能性 × 頻度
- 年間損失期待値 = 単一損失期待値 × 年間発生率

上記の値を用いてこれらの式を使用すると、以下に示すように年間損失期待値を計算できます。

- 単一損失期待値 = 60ドル（既知）
- 年間発生率 = 0.75（発生確率 (0.15) × 発生頻度 (5)）
- 年間損失期待値 = 45ドル（単一損失期待値（60ドル）× 年間発生率 (0.75)）

Question 24 of 82

If the CISO needs to determine the maximum tolerable downtime (MTD) for any given system, she will need to request which of the following?

- ☐ Disaster Recovery Plan
- ☐ Plan Inter-dependencies
- ☐ Business Impact Analysis
- ☐ Business Continuity Plan

全82問中24問目

CISOが特定のシステムにおける最大許容ダウンタイム（MTD）を決定する必要がある場合、以下のうちどれを要求する必要があるでしょうか？

- ☐ 災害復旧計画
- ☐ 相互依存関係を計画する
- ☒ **ビジネス影響分析**
- ☐ 事業継続計画

☒ **その通りです**

事業影響度分析（BIA）は、許容可能な最大ダウンタイムを決定するために策定されます。事業継続計画および復旧計画は、その目的で使用されるものではありません。また、計画間の依存関係も、最大許容ダウンタイム（MTD）の計算には使用されません。

Question 25 of 82

What can you derive from the following screen capture?

```
root@bt:~# sha1sum file5.txt
```

```
6476df3aac780622368173fe6e768a2edc3932c8 file5.txt
```

```
root@bt:~# sha1sum file6.txt
```

```
6476df3aac780622368173fe6e768a2edc3932c8 file6.txt
```

```
root@bt:~#
```

- ☐ file5.txt and file6.txt have been signed with the key
6476df3aac780622368173fe6e768a2edc3932c8
- ☐ The contents of file5.txt and file6.txt have been encrypted with the sha1
algorithm
- ☐ file5.txt and file6.txt have been encrypted with the key
6476df3aac780622368173fe6e768a2edc3932c8
- ☐ The contents of file5.txt are exactly the same as file6.txt

全82問中25問目

次のスクリーンショットから何がわかりますか？

```
root@bt:~# sha1sum file5.txt
```

```
6476df3aac780622368173fe6e768a2edc3932c8 file5.txt
```

```
root@bt:~# sha1sum file6.txt
```

```
6476df3aac780622368173fe6e768a2edc3932c8 file6.txt
```

```
root@bt:~#
```

- ☐ file5.txtとfile6.txtは、キー6476df3aac780622368173fe6e768a2edc3932c8で署名されています。
- ☐ file5.txtとfile6.txtの内容はsha1アルゴリズムで暗号化されています。
- ☐ file5.txtとfile6.txtは、キー6476df3aac780622368173fe6e768a2edc3932c8で暗号化されています。
- ☒ **file5.txtの内容はfile6.txtと全く同じです。**

☒ **その通りです**

2つのSHA1ハッシュが同じであれば、ファイルの内容は同一であることを意味します。SHA1はファイルを暗号化せず、公開鍵や秘密鍵も使用しません。

Question 26 of 82

Which zone should be used to centralize data and services so they can be shared between zone boundaries?

- ☐ Demilitarized zone
- ☐ Business zone
- ☐ Safety zone
- ☐ Enforcement zone

全82問中26問目

データとサービスをゾーン境界を越えて共有できるように、それらを一元化するにはどのゾーンを使用すべきでしょうか？

☒ 非武装地帯

☐ ビジネスゾーン

☐ 安全区

☐ 執行区域

☐ あなたは間違っています

DMZは、機能ごとに異なる一連のゾーンを提供し、ゾーン間でサービスやデータを共有できるようにする。

Question 27 of 82

You are being asked to write a utility script that runs once a month and retrieves several files from the /etc directory on all of your Linux-based embedded devices for centralized analysis. Which IT-related process does this script support?

- ☐ Baseline image testing
- ☐ Configuration monitoring
- ☐ Log collection and audit
- ☐ Patch management

全82問中27問目

あなたは、毎月1回実行され、すべてのLinuxベースの組み込みデバイスの/etcディレクトリから複数のファイルを取得して一元的に分析するユーティリティスクリプトを作成するよう依頼されています。このスクリプトは、どのIT関連プロセスをサポートしますか？

- ☐ ベースライン画像検査
- ☒ 構成監視
- ☒ ログ収集と監査
- ☐ パッチ管理

× あなたは間違っています

Linux では、/etc ディレクトリは設定ファイル用に予約されており、バイナリやログデータは含まれていないため、問題のスクリプトはデバイスの現在の設定のみを取得できます。設定監視プロセスの一環として、このデータは分析され、現在の設定が期待値に準拠しており、展開以降変更されていないことが確認されます。ログ収集とパッチ管理を参照する 2 つの回答は、/etc には設定ファイルしか含まれていないため誤りです。「ベースラインイメージのテスト」という回答も、質問文ではデバイスから中央の場所への読み取り専用のデータフローについて説明されており、ベースラインデータがデバイスにプッシュされることについては何も言及されていないため誤りです。

Question 28 of 82

Which of the following is commonly used to connect offshore oil platforms to primary control centers?

- ☐ WirelessHART
- ☐ Zigbee
- ☒ **VSAT**
- ☐ 802.11ac

全82問中28問目

洋上石油プラットフォームを主要制御センターに接続するために一般的に使用されるのは、次のうちどれですか？

- ☐ WirelessHART
- ☐ ジグビー
- ☒ **VSAT**
- ☐ 802.11ac

✓ その通りです

海上石油プラットフォームなど、あまりにも遠隔地にある場所では、機器を会社の中央制御センターに接続する唯一の方法として、衛星（VSATなど）アップリンクが選択肢となる場合がある。

WirelessHART、ZigBee、Wi-Fi（IEEE 802.11a、b、g、n、acなど）プロトコルでは、このような遠隔地に必要な距離をカバーすることはできません。

Question 29 of 82

Which of the following network reconnaissance tools is generally safe to run on a control system network?

- ☐ NMAP
- ☐ Nessus
- ☐ Wireshark
- ☐ hping

全82問中29問目

以下のネットワーク偵察ツールのうち、制御システムネットワーク上で実行しても一般的に安全なものはどれですか？

☒ **NMAP** 59710390-1bec-4f78-9e4b-ad14167339a6 (14232745)

☐ ネッソス

☒ **Wireshark**

☐ ピン

☒ **あなたは間違っています**

WiresharkやTCPDumpなどのネットワークスニファは、ポートをまたいでスイッチに安全に接続できるリスニング専用アプリケーションです。一方、NMAP、Nessus、hpingは、ネットワークにトラフィックを注入し、サーバーをアクティブにスキャンするツールです。アクティブアプリケーションは、重要なサービスのクラッシュやサービス拒否攻撃を引き起こす可能性を高めるため、重要な制御システムネットワークを危険にさらします。

Question 30 of 82

The incident response team is called to investigate ICS workstations found to be running unauthorized port scans against other systems on the network. Shortly after being scanned, some of those systems start to run port scans against additional network hosts. There is apparently no user interaction at the time of infection. What type of malware matches the described behavior?

- ☐ Trojan
- ☐ Backdoor
- ☐ Rootkit
- ☐ Worm

全82問中30問目

インシデント対応チームは、ネットワーク上の他のシステムに対して不正なポートスキャンを実行しているICSワークステーションの調査を依頼された。スキャン後もなく、これらのシステムの一部は、さらに他のネットワークホストに対してポートスキャンを開始した。感染時にユーザーによる操作は一切なかったようだ。このような挙動を示すマルウェアの種類は何か？

- ☐ トロイの木馬
- ☐ 裏口
- ☒ ルートキット
- ☒ ワーム

☒ あなたは間違っています

ワームは、ユーザーの操作を必要とせずに自己複製するマルウェアの一種です。例えば、Confickerワーム感染は、MS-086 DCOM/RPCの脆弱性を悪用しました。このワームは工場のDCSシステムに侵入し、駆除が困難でした。

Question 31 of 82

Which of the following is the most direct threat to an air-gapped system?

- ☐ Fuzzing attack
- ☐ USB thumb drive containing malware
- ☐ ARP spoofing attack
- ☐ Phishing attack
- ☐ Internet worm known to attack ICS systems

全82問中31問目

エアギャップシステムにとって最も直接的な脅威となるのは、次のうちどれですか？

- ☐ ファジング攻撃
- ☒ マルウェアを含むUSBメモリ
- ☐ ARPスプーフィング攻撃
- ☐ フィッシング攻撃
- ☐ ICSシステムを攻撃することが知られているインターネットワーム

✓ その通りです

高度な攻撃は、もともとUSBメモリを介して導入されたと言われており、悪意のある活動を行うためにシステムに物理的にアクセスすることの有効性を示しています。また、注目を集めた事件では、論理的に分離されたネットワークやエアギャップされたネットワークでさえ、このような攻撃に対して無敵ではないことが証明されています。遠隔地の施設の通信や機器を侵害するという概念も、決して新しいものではありません。セキュリティ専門家は、企業顧客向けに承認されたネットワーク侵入テストを実施する際に、しばしばこのような戦術を用います。

その他の攻撃はすべて、攻撃者がネットワーク上に存在することを前提としており、これはエアギャップによって防止されるべきである。

Question 32 of 82

Which type of cryptographic algorithm solves the problem of secure key exchange?

- ☐ Symmetric
- ☐ Substitution Cipher
- ☐ Hashing
- ☐ Permutation Cipher
- ☐ Asymmetric

全82問中32問目

安全な鍵交換の問題を解決する暗号アルゴリズムの種類はどれですか？

- ☐ 対称的
- ☐ 置換暗号
- ☐ ハッシュ化
- ☒ 順列暗号
- ☒ 非対称

❌ あなたは間違っています

非対称アルゴリズムは公開鍵と秘密鍵のシステムを使用するため、対称アルゴリズムとは異なり、単一の鍵を共有する必要はありません。ハッシュ化は鍵を使用しませんが、元に戻せない一方関数でもあります。

置換と順列は暗号アルゴリズムで使われる手法ですが、アルゴリズムの種類ではありません。ほとんどのアルゴリズムは、目的の結果を得るために、置換、置換、およびその他の変換を組み合わせで使用します。

Question 33 of 82

An organization has been vulnerable to a specific CVE for two years. Last week a metasploit module was released to exploit the vulnerability in an automated fashion. What happened to the vulnerability?

- ☐ It remained the same
- ☐ It changed categories
- ☐ It decreased
- ☐ It increased

全82問中33問目

ある組織は、2年間特定のCVEに対して脆弱な状態に置かれていました。先週、その脆弱性を自動的に悪用するMetasploitモジュールがリリースされました。この脆弱性はどうなったのでしょうか？

☒ **それは変わらなかった**

- ☐ カテゴリーが変わりました
- ☐ 減少した
- ☐ 増加した

☒ **その通りです**

脆弱性は不変であり、存在するか存在しないかのどちらかです。既存の脆弱性は、パッチ適用などの何らかの対策によって解消できます。脆弱性に関連するリスクは、増加、減少、またはカテゴリの変更が生じる可能性があります、それは脆弱性自体が変化するのではなく、リスク計算における他の変数が変化するためです。

Question 34 of 82

A working group consisting of top subject matter experts from at least a dozen organizations in the industry is developing a security document that details what vendors must do if they are to provide field widgets that are reasonably secure. If this document is successful in being adopted, many vendors of field widgets will need to comply with it. Which type of document is the working group developing?

- ☐ Procedure
- ☐ Standard
- ☐ Policy
- ☐ Guideline

全82問中34問目

業界の少なくとも12の組織から集まった一流の専門家で構成されるワーキンググループが、ベンダーが適切なセキュリティを備えたフィールドウィジェットを提供するために遵守すべき事項を詳述したセキュリティ文書を作成しています。この文書が採用されれば、多くのフィールドウィジェットベンダーがこれに準拠する必要が生じます。ワーキンググループが作成している文書はどのような種類のものでしょうか？

☐ 手順

☒ 標準

☐ ポリシー

☒ ガイドライン

✕ あなたは間違っています

規格は、高レベルかつ具体的なものになり得ます。関連性があり採用されている場合、多くの組織はその規格に「準拠」することが求められます。規格には認証が付随することもあります。組織や製品は認証を受けるか、準拠しているとみなされます。手順とは、非常に具体的なタスクを繰り返し実行するための段階的な指示です。ポリシーは、より高レベルの記述です。ガイドラインは、ポリシーと手順の中間に位置し、より曖昧で一般的なガイダンスを提供します。

Question 35 of 82

Which level of the Purdue Enterprise Reference Architecture (PERA) groups systems that support site-wide operations?

☐ 2

☐ 4

☐ 5

☐ 3

全82問中35問目

Purdue Enterprise Reference Architecture (PERA) のどのレベルで、サイト全体の運用をサポートするシステムがグループ化されていますか？

☐ 2

☐ 4

☐ 5

☒ 3

✔ その通りです

パデューモデルでは、システムを0から4までの5つの異なるレベルに分割することを提案しています。レベル0は最も低いレベルで、物理的なプロセスを表し、そのグループのプロセスを構成する直接的なセンサーとアクチュエータが含まれます。レベル1には、そのグループのプロセスのコントローラが含まれます。レベル2には、各グループのプロセスに固有のローカル監視システムが含まれます。プロセスグループの上には、工場全体または地域全体のレベル3があり、そのサイトまたはその地域のすべてのプロセスグループを制御する監視システムが含まれます。レベル3には、運用をサポートするシステムで構成されますが、プロセスのリアルタイム実行には直接関与しない運用サポートも含まれます。レベル4は、ICSに関連する組織のビジネス面を表します。パデューモデルの現代的な進化では、多くの場合、すべての企業ビジネスユニットに対するエンタープライズサポートを表すレベル5が含まれます。

Question 36 of 82

Which of the following demonstrates the recommended level of detail for a mobile device encryption policy statement?

- ☐ Mobile devices should be protected with BitLocker full disk encryption
- ☐ The following steps shall be used to enable full disk encryption
- ☐ Data at rest on mobile devices must be secured
- ☐ Approved third party disk encryption can be used on mobile devices running the Linux operating system

全82問中36問目

モバイルデバイスの暗号化ポリシー記述書において推奨される詳細レベルを示すのは、次のうちどれですか？

- ☐ モバイルデバイスはBitLockerによるフルディスク暗号化で保護されるべきである。
- ☒ フルディスク暗号化を有効にするには、以下の手順を使用します。
- ☒ モバイルデバイスに保存されているデータは保護されなければならない
- ☐ 承認されたサードパーティ製のディスク暗号化は、Linuxオペレーティングシステムを実行しているモバイルデバイスで使用できます。

☒ あなたは間違っています

ポリシーには、どのように行うべきかではなく、何を行うべきかを記述する高レベルの記述が含まれます。「モバイルデバイスに保存されているデータは保護されなければならない」という記述は、高レベルのポリシー記述の一例であり、標準、ガイドライン、手順といった他のすべての選択肢によって裏付けられています。

Question 37 of 82

Which of the following Windows event logs would the analyst review in order to determine whether there is a device driver issue?

- ☐ Administrative
- ☐ Security
- ☐ Application
- ☐ System

全82問中37問目

アナリストがデバイスドライバの問題の有無を判断するために確認するWindowsイベントログは次のうちどれですか？

- ☐ 管理
- ☐ 安全
- ☐ 応用
- ☒ システム

✓ その通りです

デバイスドライバの問題はシステムログに記録されます。管理者が最初に確認すべき場所としては、そこが論理的に適切でしょう。

Question 38 of 82

An RTOS buffer overflow vulnerability poses the most security risk to which of the following?

- ☐ Historian database servers
- ☐ Web applications that accept user input
- ☐ Embedded system firmware
- ☐ Switches with span ports

全82問中38問目

RTOSのバッファオーバーフローの脆弱性は、以下のうちどれに対して最も大きなセキュリティリスクをもたらしますか？

- ☐ 歴史データベースサーバー
- ☐ ユーザー入力を受け付けるWebアプリケーション
- ☒ **組み込みシステムファームウェア**
- ☐ スパンポート付きスイッチ

☒ その通りです

組み込みシステムとは、特定のタスク向けに設計され、それらのタスクをサポートするように調整されたシステムです。RTOSは、組み込みデバイス上で動作するリアルタイムオペレーティングシステムであり、従来のコンピュータで使用するオペレーティングシステムのようなオーバーヘッドなしに機能を提供します。RTOSシステムでは、カーネル空間とユーザー空間が分離されていることはほとんどありません。組み込みシステムの脆弱性を発見した場合、攻撃者は権限昇格やその他の脆弱性の連鎖を必要とせずに、システムを完全に制御できる可能性が高くなります。

Question 39 of 82

Data correlation between devices that are geographically separated by large distances requires which of the following?

- ☐ Accurate timestamps from the I/O devices
- ☐ Devices using identical operating systems
- ☐ Very low latency rates between the devices
- ☐ Devices using a wired 1 Gbps link

全82問中39問目

地理的に大きく離れたデバイス間のデータ相関には、次のうちどれが必要ですか？

- ☒ 入出力デバイスからの正確なタイムスタンプ
- ☐ 同一のオペレーティングシステムを使用するデバイス
- ☐ デバイス間の遅延が非常に低い
- ☐ 有線1Gbpsリンクを使用するデバイス

☒ その通りです

時間同期は、電力網のような高度に分散したSCADAシステムにおいて非常に重要となる。電力網では、数百マイル離れた機器間や制御センター間でデータを相関させる必要がある場合がある。

Question 40 of 82

What can be done to get malicious code to execute when a computer starts up?

- ☐ Use filesystem slack space to store it
- ☐ Use pagefile.sys to launch it
- ☐ Inject it into RAM memory
- ☐ Use the BIOS to launch a script that calls it
- ☐ Place it in the boot sector

全82問中40問目

コンピュータの起動時に悪意のあるコードを実行させるには、どのような方法がありますか？

- ☐ ファイルシステムの空き領域を使用して保存します。
- ☐ pagefile.sys を使用して起動します。
- ☐ RAMメモリに注入する
- ☐ BIOSを使用して、それを呼び出すスクリプトを起動します。
- ☒ **ブートセクターに配置してください**

☒ その通りです

BIOSはスクリプトの呼び出しには使用できず、pagefile.sysは物理メモリがいっぱいになった場合にのみアクセスされ、RAMメモリはマシンの電源サイクルごとにクリアされます。また、悪意のあるコードはスラック領域に格納できますが、自動的に起動することはありません。ブートセクタ内のコードは、OSが起動するたびに実行されます。

Question 41 of 82

A reactor operator at a nuclear power plant can control Pump_A on Unit 1 and Pump_B on Unit 2 from a single, centralized HMI. What level of the Purdue model are the pumps in?

- ☐ Level 4
- ☐ Level 3
- ☐ Level 1
- ☐ Level 0
- ☐ Level 2

全82問中41問目

原子力発電所の原子炉運転員は、単一の中央集中型HMIから、1号機のポンプAと2号機のポンプBを制御できます。これらのポンプは、パーデューモデルのどのレベルに該当しますか？

☐ レベル4

☐ レベル3

☐ レベル1

☒ レベル0

☐ レベル2

✕ あなたは間違っています

ポンプやバルブなどのコンポーネントは直接的なプロセスの一部であるため、レベル0に分類されます。HMIは工場全体に適用されるため、レベル2ではなくレベル3とみなされますが、これは下位レベルのコントローラーやポンプなどの機器には影響しません。

Question 42 of 82

Which of the following systems logged the Syslog event below?

Jan 23 03:12:41 ip-192-168-10-42 sshd[514]: Invalid user admin from 192.168.10.13

- ☐ The host named sshd
- ☐ The host at 192.168.10.42
- ☐ The host named admin
- ☐ The host at 192.168.10.13

全82問中42問目

以下のシステムのうち、下記のSyslogイベントを記録したのはどれですか？

Jan 23 03:12:414 ip-192-168-10-42 sshd[514]: Invalid user admin from 192.168.10.13

- ☐ sshdという名前のホスト
- ☒ ホストは192.168.10.42です
- ☐ adminという名前のホスト
- ☐ ホストは192.168.10.13です

✓ その通りです

日付/時刻スタンプの後に続くフィールド「ip-192-168-10-42」は、syslogエントリを送信したマシンです。sshdは、エントリを報告したプログラムの名前です。adminとIP 192.168.10.13はどちらもメッセージデータであり、この場合はログインを試みたアカウント名と、その試行が行われたIPアドレスを示しています。

Question 43 of 82

What is an example of deterrence as a physical security defense?

- ☐ Physical walk-down
- ☐ Bright lighting
- ☐ Hidden cameras
- ☐ Audible alarms

全82問中43問目

物理的な安全保障対策としての抑止力の例を挙げてください。



物理的な徒歩移動



明るい照明



隠しカメラ



可聴アラーム



あなたは間違っています

物理的なセキュリティ対策には、抑止、遅延、検知、対応が含まれます。抑止とは、攻撃者が攻撃を試みる可能性を低減するあらゆるセキュリティ機能を指します。例としては、有刺鉄線付きの高いフェンス、目に見えるカメラ、明るい照明、目立つ警備員などが挙げられます。侵入を施設職員に知らせる可聴アラームは、検知の一例です。完全に効果的な抑止策であれば、可聴アラームの使用は不要になります。物理的な巡回点検とは、経験豊富な現場職員が、何か紛失または異常がないかを確認するために行う検査です。

Question 44 of 82

For which purpose would a security analyst use mbtget?

- ☐ To enumerate HTTP traffic on a web-enabled HMI
- ☐ To discover weak session management on a web application
- ☐ To send commands to test a PROFIBUS device
- ☐ To interact with the modbus-tcp protocol

セキュリティアナリストはどのような目的でmbtgetを使用するのでしょうか？

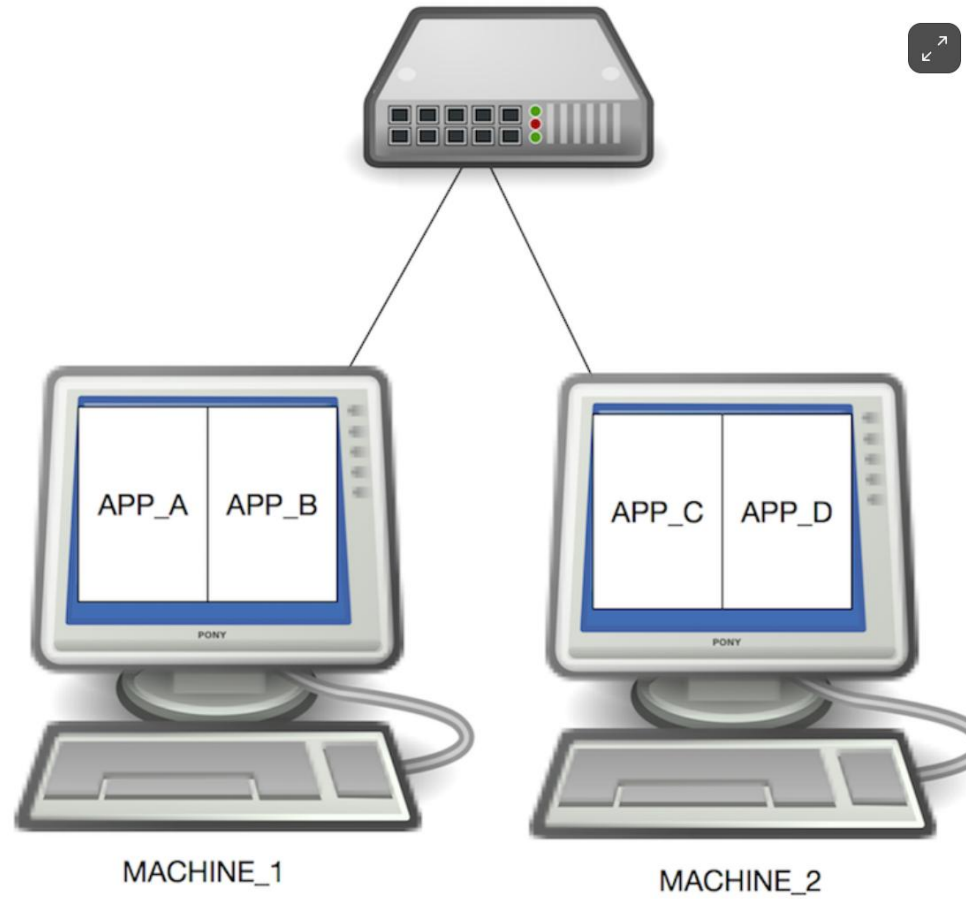
- ☒ **ウェブ対応HMI上のHTTPトラフィックを列挙する**
- ☐ Webアプリケーションにおける脆弱なセッション管理を発見する
- ☐ PROFIBUSデバイスをテストするためのコマンドを送信する
- ☒ **modbus-tcpプロトコルとやり取りするには**

× あなたは間違っています

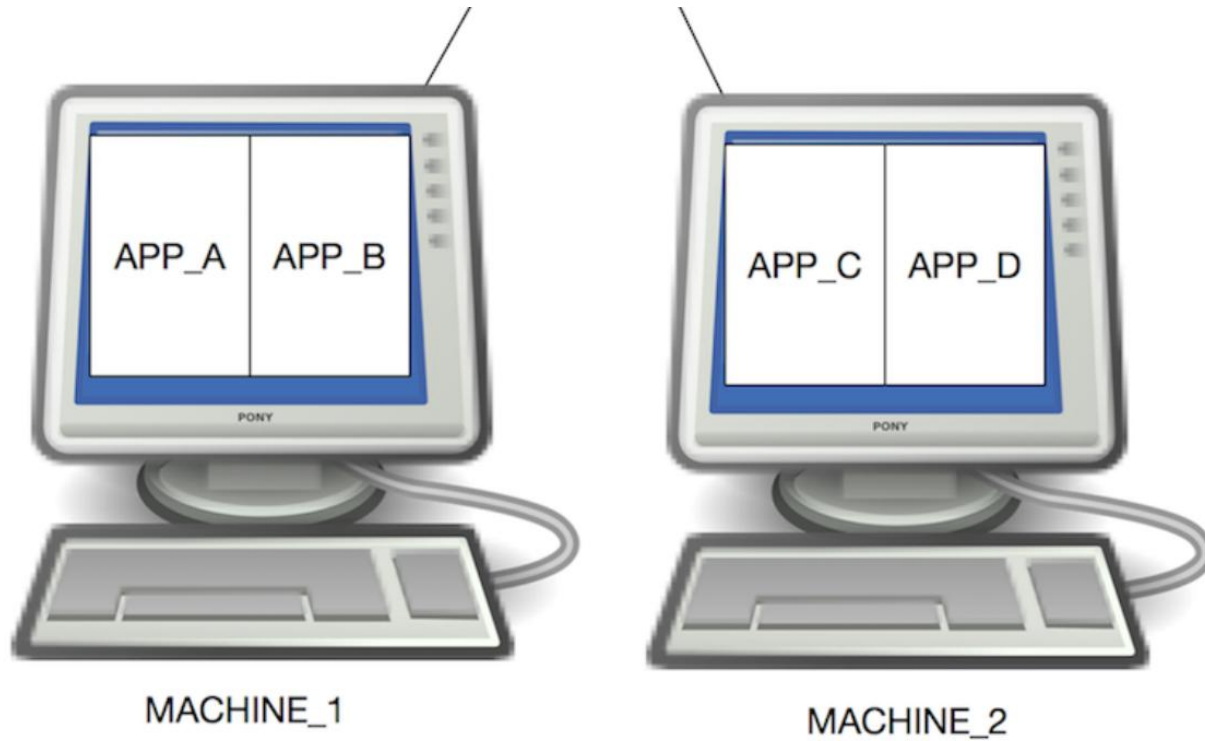
mbtgetは、最も一般的に使用されているTCP/IPベースのICSプロトコルの1つであるmodbus-tcpプロトコルと連携できます。mbtgetのようなツールを使用すると、攻撃者は実行中のICSプロセスを変更するmodbusコマンドを簡単に作成でき、プロセスを停止させたり、さらに悪いことに、プロセスを実行している企業やエンジニアに最大限の影響を与えるようにICSプロセスを改変したりすることができます。

Question 45 of 82

An engineer has access to four web applications within an organization; App_A, App_B, App_C, and App_D. App_A and App_B are normally accessed from MACHINE_1, App_C and App_D are normally accessed from MACHINE_2. While using App_B a user had their cookie and session token stolen. Which statement most accurately describes how the attacker could impersonate the engineer while the stolen credentials are valid?



- ☐ Within any of the four apps from MACHINE_1
- ☐ Within App_B from any machine
- ☐ Within any of the four apps from any machine
- ☐ Within App_B from MACHINE_1



- ☐ MACHINE_1の4つのアプリのいずれか内で
- ☒ **どのマシンからでもApp_B内で**
- ☐ どのマシンからでも、4つのアプリのいずれか内で
- ☐ MACHINE_1 の App_B 内

☒ **その通りです**

Cookieはアプリケーション固有のものであるため、App_B用のCookieはApp_B内でのみ有効です。Cookieを使用して他のユーザーになりすます場合、特定のコンピュータを使用する必要はありません。

Question 46 of 82

Where should an in-line, transparent, ICS firewall be placed on a network?

- ☐ At a network boundary
- ☐ Between HMI devices
- ☐ In front of a controller
- ☐ At a DMZ boundary

全82問中46問目

インライン型で透過的なICSファイアウォールは、ネットワーク上のどこに配置すべきでしょうか？

- ☐ ネットワーク境界において
- ☐ HMIデバイス間
- ☒ **コントローラーの前で**
- ☐ DMZの境界で

☒ **その通りです**

これらのファイアウォールは、ICSアーキテクチャの下位レベル（レベル2以下）で使用され、コントローラや安全システムPLCへのトラフィックをフィルタリングします。保護対象機器と直列に接続する必要があります。

Question 47 of 82

What is the result of the following command?

```
wmic.exe /node:192.168.1.66 SHARE
```

- ☐ Turn on share settings for 192.168.1.66
- ☐ List shared drives on 192.168.1.66
- ☐ Create a shared drive on 192.168.1.66
- ☐ Connect to the share on 192.168.1.66

全82問中47問目

以下のコマンドを実行すると、どのような結果になりますか？

```
wmic.exe /node:192.168.1.66 SHARE
```

- ☐ 192.168.1.66 の共有設定をオンにする
- ☒ **192.168.1.66 の共有ドライブの一覧を表示します**
- ☐ 192.168.1.66 上に共有ドライブを作成します。
- ☒ **192.168.1.66 の共有フォルダに接続します。**

× あなたは間違っています

Wmic.exe は、変数を取得および設定することで Windows マシンを管理するために使用されます。この例では、マシン上のすべての共有の一覧が返されます。結果の表示方法は、たとえば次のように変更できます。

```
wmic.exe /node:192.168.1.66 SHARE list brief
```

出力は簡潔なリスト形式で表示されます。（リストなどの表示オプションは必須ではありません。）

Question 48 of 82

A vendor is remotely connected to a client's HMI workstation. The vendor is browsing a popular forum to assist in troubleshooting the HMI. The vendor accidentally clicked on the following hidden link and valve 41234 in the plant closed. What kind of attack was this?

<http://hmi.SillyVendor.com/close?valve=41234>

- ☐ Cross-site scripting
- ☐ SQL injection
- ☐ Cross-site request forgery
- ☐ Remote file inclusion

全82問中48問目

ベンダーが顧客のHMIワークステーションにリモート接続しています。ベンダーはHMIのトラブルシューティングを支援するために、人気のフォーラムを閲覧していました。ベンダーが誤って以下の隠しリンクをクリックしたところ、工場内のバルブ41234が閉じてしまいました。これはどのような種類の攻撃だったのでしょうか？

<http://hmi.SillyVendor.com/close?valve=41234>

- ☐ クロスサイトスクリプティング
- ☐ SQLインジェクション
- ☒ クロスサイトリクエストフォージェリ
- ☐ リモートファイルインクルージョン

☒ その通りです

これはクロスサイトリクエストフォージェリの一例です。URLによって指示されたアクションは、ベンダーがクライアントのHMIワークステーション上で持つ権限と同じ権限で実行されます。

Question 49 of 82

What does the command shown accomplish?

iptables -F

- ☐ Resets the table of established connections
- ☐ Drops rejected packets without logging
- ☐ Clears existing firewall rules
- ☐ Displays the existing firewall rules

全82問中49問目

表示されているコマンドは何を実行しますか？

`iptables -F`

- ☐ 確立された接続のテーブルをリセットします
- ☐ ログを記録せずに拒否されたパケットを破棄する
- ☒ 既存のファイアウォールルールをクリアします
- ☐ 既存のファイアウォールルールを表示します

☒ その通りです

「iptables -F」はiptablesのルールをフラッシュします。確立された接続は、明示的に終了されるかタイムアウトするまで維持されます。

Question 50 of 82

Which of the following is the type of document you would use to communicate to field engineers in detail how the firmware is to be upgraded on a particular RTU?

- ☐ Procedure
- ☒ **Guideline**
- ☐ Policy
- ☐ Standard

全82問中50問目

特定のRTUのファームウェアをどのようにアップグレードするかを現場のエンジニアに詳細に説明するために使用する文書の種類は、次のうちどれですか？

☒ 手順
5971b396-1b5c-4f78-9e4b-ad14167339a6 (14232745)

☐ ガイドライン

☐ ポリシー

☐ 標準

☒ あなたは間違っています

手順とは、特定のタスクを繰り返し実行するための段階的な指示です。RTUのファームウェアのアップグレードのようなタスクは、その重要性から手順を作成するのに最適です。ポリシーは、より高レベルの記述です。ガイドラインは、ポリシーと手順の中間に位置し、より漠然とした一般的なガイダンスを提供します。標準とは、組織やデバイスに固有のものではないものです。

Question 51 of 82

Which of the following is best verified through the use of hashing?

- ☐ Integrity
- ☐ Availability
- ☐ Confidentiality

全82問中51問目

ハッシュ関数を用いることで最も適切に検証できるのは、次のうちどれですか？

☒ 誠実さ

☐ 可用性

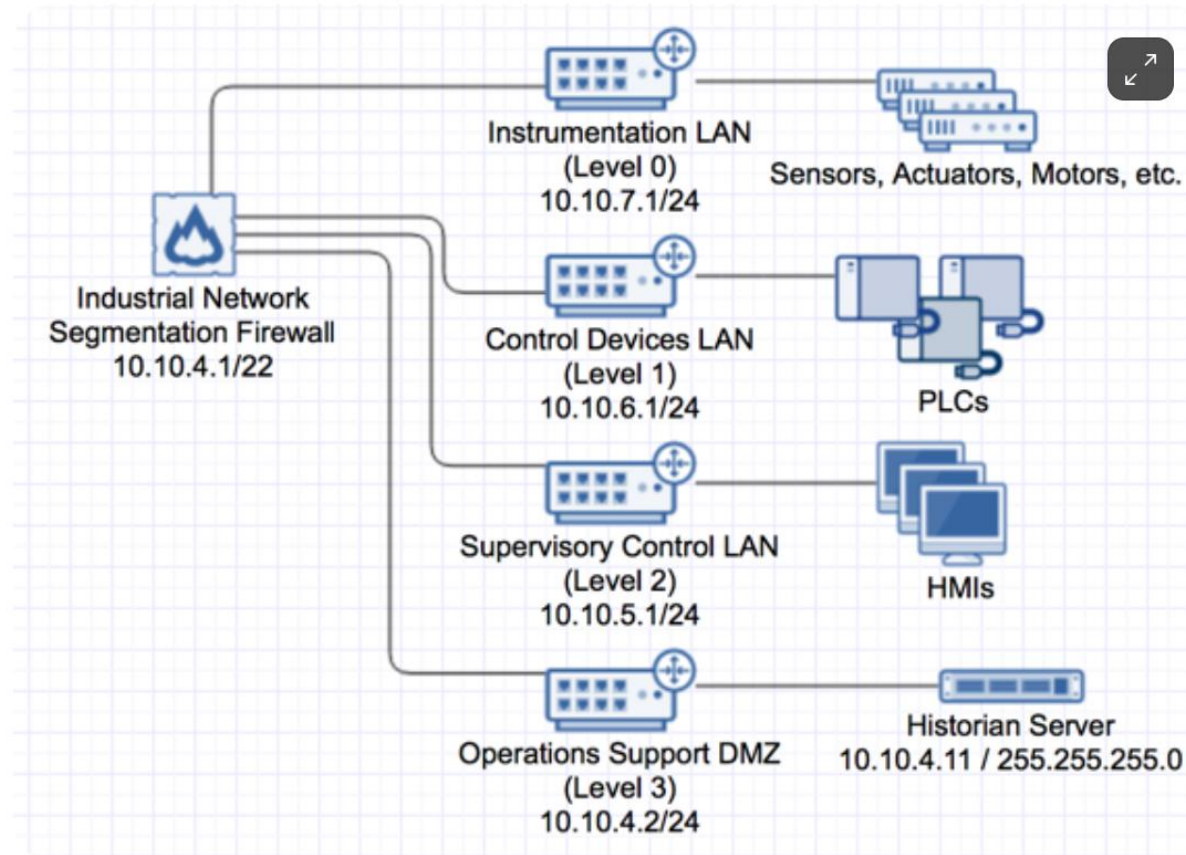
☐ 機密保持

☒ その通りです

ハッシュ化は、ファイルが改ざんされていないことを検証するために使用される一方向関数です。ハッシュ化は元に戻せないため、データの機密性を保つ目的での送信には適していません。データがハッシュ化されると、元の形式では利用できなくなります。

Question 52 of 82

Using the network diagram for context, which of the following source IP addresses would be blocked from connecting to the Instrumentation LAN by an anti-spoofing rule on the firewall?



59719396-15cc-4778-9e4b-ad14167339a6 (14232745)



10.10.7.187



10.10.6.24

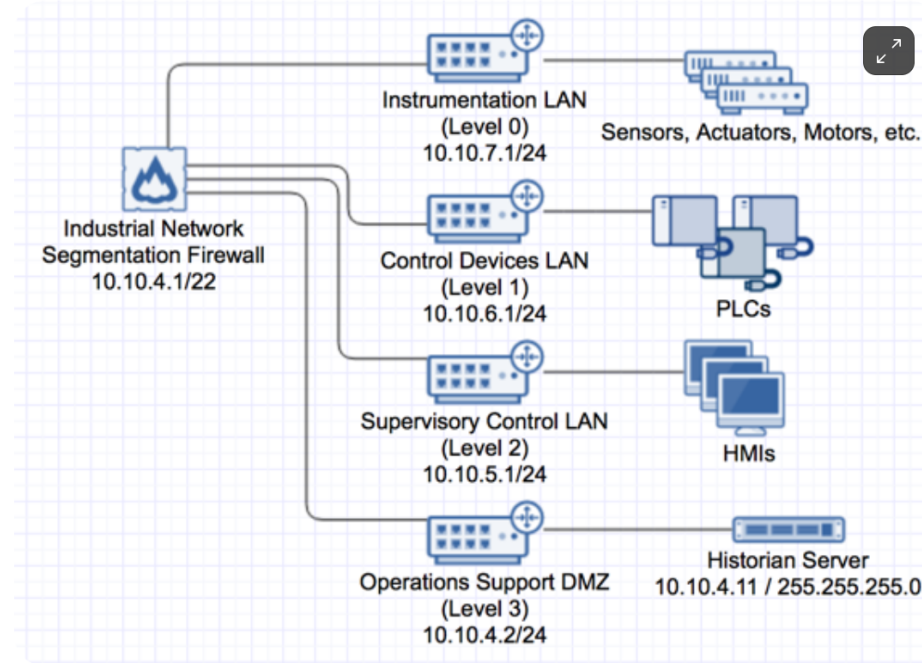


10.10.4.3



10.10.5.77

ネットワーク図を参考に、ファイアウォールのなりすまし防止ルールによって計測LANへの接続がブロックされる送信元IPアドレスは次のうちどれですか？



☒ 10.10.7.187

☐ 10.10.6.24

☐ 10.10.4.3

☐ 10.10.5.77

☒ その通りです

保護されたネットワークアドレス空間内の送信元アドレスを含む受信パケットはすべて破棄する必要があります。これらのパケットが攻撃者によるアドレスのなりすましによるものか、ルーティングの問題によるものかにかかわらず、受信を許可してはなりません。10.10.4.0/24、10.10.5.0/24、および10.10.6.0/24ネットワークをブロックする理由は他にも考えられますが、なりすましは理由になりません。

Question 53 of 82

Which of the following tasks would be done during the containment phase of the incident handling process?

- ☐ An administrator isolating an affected system on a network
- ☐ An operator scanning an affected system with anti-malware software
- ☐ An incident handler testing a restore process checklist
- ☐ A user reporting a system acting abnormally to the help desk

全82問中53問目

インシデント対応プロセスの封じ込めフェーズでは、以下のどのタスクが実施されますか？

- ☒ ネットワーク上で影響を受けたシステムを隔離する管理者
- ☒ オペレーターがマルウェア対策ソフトウェアを使用して感染したシステムをスキャンしている
- ☐ インシデントハンドラーが復旧プロセスチェックリストをテストしている
- ☐ ユーザーがシステムの異常動作をヘルプデスクに報告する

☒ あなたは間違っています

プロセスチェックリストのテストは準備段階の一部です。異常な動作をしているシステムを報告することは、特定作業です。管理者がネットワーク上で影響を受けたシステムを隔離することは、封じ込め作業です。オペレーターが影響を受けたシステムをスキャンすることは、根絶作業です。

Question 54 of 82

Which of the following contains the logic and parameters for Programmable Logic Controllers (PLCs)?

- ☐ Front End Processor
- ☒ **Project Files**
- ☐ Historian
- ☐ Human Machine Interface

全82問中54問目

次のうち、プログラマブルロジックコントローラ（PLC）のロジックとパラメータが含まれているのはどれですか？

- ☐ フロントエンドプロセッサ
- ☒ プロジェクトファイル
- ☐ 歴史家
- ☐ ヒューマンマシンインターフェース

✓ その通りです

PLC が実行するタスクはハードコーディングされていません。名前が示すように、PLC の機能はプログラムで設定できます。エンジニアリングワークステーションによく保存されているプロジェクトファイルには、制御システム、ネットワークアーキテクチャ、構成、および PLC のロジックとパラメータの詳細が含まれています。そのため、攻撃者にとって格好の標的となります。ヒューマンマシンインターフェースは、オペレータにデータを提供しますが、自動化されたプロセスのロジックは含まれていません。ヒストリアンにはイベントログが含まれており、多くの場合 SQL データベースに保存されます。フロントエンドプロセッサは、RTU (リモートターミナルユニット) と管理システム間の通信を監視します。

Question 55 of 82

Why may a Windows Application log fail to provide information about an application problem?

- ☐ The LOGEVENT.EXE process has stopped
- ☐ The server administrator did not enable application logging
- ☐ Application logging does not include a field for description
- ☐ The application developer did not specify logging information for the problem

全82問中55問目

Windowsアプリケーションログがアプリケーションの問題に関する情報を提供しないのはなぜですか？

- ☐ LOGEVENT.EXE プロセスが停止しました
- ☐ サーバー管理者がアプリケーションログを有効にしていませんでした
- ☒ アプリケーションログには説明欄がありません
- ☒ アプリケーション開発者は、この問題に関するログ情報を指定していません。

✕ あなたは間違っています

アプリケーションログには、開発者が定義および記述した条件が記録されます。開発者が問題のログ記録を選択しなかった場合、アプリケーションログにはエントリが表示されません。サーバー管理者が有効化する必要があるセキュリティログとは異なり、アプリケーションログはデフォルトで実行されます。LOGEVENT.EXE は、管理者が任意のログ情報をログに挿入するために使用するオプションのコマンドラインツールであり、Windows のイベントログサービスのように自動的に問題をログに記録する機能はありません。アプリケーションログには、他のログと同じイベントフィールドが表示されます。

Question 56 of 82

Compare the ACLs from June and July listed below. Which of the following changes should be investigated further?

*****Firewall101--June*****

```
access-list inbound permit tcp any host 10.10.10.220 eq www
access-list inbound permit tcp host 10.10.33.66 host 10.10.10.16 eq 1433
access-list inbound permit udp host 10.10.33.66 host 10.10.10.16 eq 1433
access-list inbound permit tcp any host 10.10.10.252 eq 8080
access-list inbound permit tcp any host 10.10.10.252 eq ssh
access-list inbound permit tcp any host 10.10.10.252 eq https
access-list inbound permit tcp any host 10.10.10.4 eq www
access-list inbound permit tcp any host 10.10.10.252 eq smtp
access-list inbound permit tcp host 10.10.207.91 host 10.10.10.17 eq ssh
access-list inbound permit tcp any host 10.10.10.100 eq 81
```

*****Firewall101--July*****

```
access-list inbound permit tcp any host 10.10.10.220 eq 80
access-list inbound permit tcp host 10.10.33.66 host 10.10.10.16 eq 1433
access-list inbound permit udp host 10.10.33.66 host 10.10.10.16 eq 1433
access-list inbound permit tcp any host 10.10.10.252 eq 8080
access-list inbound permit tcp any host 10.10.10.252 eq ssh
access-list inbound permit tcp any host 10.10.10.252 eq 443
access-list inbound permit tcp any host 10.10.10.4 eq www
access-list inbound permit tcp any host 10.10.10.252 eq 25
access-list inbound permit tcp host 10.10.207.91 host 10.10.10.17 eq 22
access-list inbound permit tcp host 10.10.207.91 host 10.10.10.17 eq 23
access-list inbound permit tcp any host 10.10.10.100 eq 81
```

- ☐ Any host can connect to 10.10.10.220 by port 80
- ☐ 10.10.207.91 can connect to 10.10.10.17 by 22
- ☐ Any host can connect to 10.10.10.252 by port 443
- ☐ 10.10.207.91 can connect to 10.10.10.17 by 23

- 5971b396-1bec-4178-9e4b-ad14167359a6 (14232745)
- ☐ どのホストもポート80経由で10.10.10.220に接続できます。
 - ☐ 10.10.207.91 は 22 を介して 10.10.10.17 に接続できます
 - ☐ どのホストもポート443経由で10.10.10.252に接続できます。
 - ☒ **10.10.207.91 は 23 を介して 10.10.10.17 に接続できます**

☒ **その通りです**

10.10.207.91 は、telnet (ポート 23) 経由で 10.10.10.17 に接続できるようになりました。SSH (ポート 22) 経由では、これまでも接続可能でした。任意のホストは、www トラフィックであるポート 80 を介して 10.10.10.220 に接続できます。このルールは変更されていません。任意のホストは、https トラフィックであるポート 443 を介して 10.10.10.252 に接続できます。このルールも変更されていません。

Question 57 of 82

Which of the following is a RF networking topology that is used in protocols like WirelessHART, ISA100.11a and Zigbee that allows each participating device to act as a gateway to other devices?

- ☐ Token
- ☐ Mesh
- ☐ Bus
- ☐ Star

以下のうち、WirelessHART、ISA100.11a、Zigbeeなどのプロトコルで使用され、参加する各デバイスが他のデバイスへのゲートウェイとして機能することを可能にするRFネットワークトポロジーはどれですか？

- ☐ トークン
- ☒ メッシュ
- ☐ バス
- ☐ 星

✓ その通りです

RFメッシュネットワークでは、参加する各デバイス（ノード）が他のデバイスにデータをルーティングできるため、すべてのデバイスが中央アクセスポイントを認識できないといった問題を回避できます。少数のノードが他のノードへのゲートウェイとして機能し、セルラーなどのWANネットワークに到達するまで、より長距離の通信を可能にします。

無線ネットワークで一般的に使用されるのは、以下のような場合です。

- デバイスの数が多い
- デバイスがすべて中央アクセスポイントを認識するのに問題がある
- より柔軟な「自己修復」ネットワークが望ましい
- レイテンシはそれほど問題にならない

メッシュ接続は、WirelessHART、ISA100.11a、ZigbeeなどのICSプロトコルで使用されます。

Question 58 of 82

When a HMI panel displays an alarm from a device's tamper sensor, which type of physical security control does it indicate?

- ☐ Prevention
- ☐ Response
- ☐ Deterrence
- ☐ Detection

全82問中58問目

HMIパネルにデバイスの改ざんセンサーからのアラームが表示された場合、それはどのようなタイプの物理的セキュリティ制御を示しているのでしょうか？

- 5971b39b-1b5c-4f78-9e4b-ad14167339a6 (14232745)
- ☐ 防止
 - ☐ 応答
 - ☒ 抑止力
 - ☒ 検出

✖ あなたは間違っています

改ざん検知センサーは、セキュリティ侵害が発生した可能性を検知し、攻撃者を特定できます。物理的な抑止力は攻撃の試みの可能性を低減し、遅延機能は攻撃者の行動を遅らせます。物理的な認証レベルは、許可された担当者のみがエリアにアクセスできるようにする機能であり、対応機能は物理的な防御の最終段階であり、攻撃の結果として担当者と手順を発動します。

Question 59 of 82

What is a recommended practice for securing a database in an ICS environment?

- ☐ Don't run backend databases on a virtual machine
- ☐ Use a single table to hold all of the domain values
- ☐ Don't use the same certificate to authenticate client and server connections
- ☐ Limit administrative database roles to just domain admins

全82問中59問目

ICS環境におけるデータベースのセキュリティを確保するための推奨される方法は何ですか？

- ☐ バックエンドデータベースを仮想マシン上で実行しないでください
- ☐ ドメイン値をすべて保持するために単一のテーブルを使用する
- ☒ クライアントとサーバーの接続認証に同じ証明書を使用しないでください。
- ☒ 管理データベースの役割をドメイン管理者のみに制限する

✖ あなたは間違っています

データベースを保護するための推奨事項には、クライアント接続とサーバー接続の両方に同じ証明書を使用して暗号化/認証を行わないこと、アプリケーション/データベースのペアごとに固有のユーザー名/パスワードを使用すること、ドメイン管理者ユーザーアカウントを使用しないこと、特にSQLインターフェースにおける安全でない関数呼び出しを制限することなどが含まれます。また、すべてのドメイン値を1つのテーブルに保持することは推奨されません。

Question 60 of 82

Which device can be used to prevent a MODBUS write command from being executed on a PLC where only read commands are expected?

- ☐ Data diode
- ☒ **Application-layer firewall**
- ☐ Network intrusion detection sensor
- ☐ Packet-filtering firewall

全82問中60問目

読み取りコマンドのみが想定されるPLCで、MODBUS書き込みコマンドが実行されないようにするには、どのデバイスを使用すればよいですか？

- ☐ データダイオード
- ☒ アプリケーション層ファイアウォール
- ☐ ネットワーク侵入検知センサー
- ☐ パケットフィルタリングファイアウォール

✓ その通りです

アプリケーションファイアウォール（「次世代ファイアウォール」とも呼ばれる）は、アプリケーションレベルでプロトコルを解釈し、パケットの値と内容に基づいて判断を下すことができます。アプリケーションファイアウォールのルールは、定義された範囲外の値を含むトラフィックを破棄するように設定できます。パケットフィルタリングファイアウォールは、送信元および宛先IPアドレスやポートなど、パケットのネットワーク層およびトランスポート層ヘッダーに含まれる情報に基づいて判断を下します。

Question 61 of 82

Which of the following protocols allows an organization to use its existing IPv6 addressing scheme?

- ☐ WirelessHART
- ☐ ISM band
- ☐ ISA100.11a
- ☐ Bluetooth

全82問中61問目

以下のプロトコルのうち、組織が既存のIPv6アドレス体系を使用できるようにするものはどれですか？

- ☐ WirelessHART
- ☐ ISMバンド
- ☒ **ISA100.11a**
- ☐ ブルートゥース

✓ その通りです

ISA100.11aは、アドレス指定とサブネット化のスケラビリティのためにIPv6を活用しています。WirelessHARTはIPv4をサポートしていますが、IPv6はサポートしていません。

Question 62 of 82

The IEEE 802.1x standard defines which of the following?

- ☐ Subnet roaming
- ☐ Frequency hopping
- ☐ Authentication
- ☐ Modulation
- ☐ Wireless communication

全82問中62問目

IEEE 802.1x規格では、次のうちどれが定義されていますか？

- ☐ サブネットローミング
- ☐ 周波数ホッピング
- ☒ 認証
- ☐ 変調
- ☒ 無線通信

× あなたは間違っています

なりすまし攻撃から保護するためには、アクセスポイントに対するユーザーの認証と、ユーザーに対するアクセスポイントの認証を行う仕組みが必要です。これは、IEEE 802.1Xネットワーク認証プロトコルと、EAP/TLS、PEAP、TTLSなどの相互認証をサポートする拡張認証プロトコルを使用することで実現できます。

Question 63 of 82

An attacker is able to adjust settings on a GPO that will be pushed out across all workstations. What is the maximum amount of time before workstations will download the malicious GPOs?

- ☐ 90 minutes
- ☐ 120 minutes
- ☐ 30 minutes
- ☐ 60 minutes

全82問中63問目

攻撃者は、すべてのワークステーションに展開されるGPOの設定を変更できます。ワークステーションが悪意のあるGPOをダウンロードするまでの最大時間はどれくらいですか？



90分



120分



30分



60分



あなたは間違っています

ドメイン内のマシンは、90分から120分ごとにグループポリシーオブジェクト（GPO）が変更されていないか自動的に確認し、変更されている場合は新しいGPOをダウンロードするように構成されています。上限が120分であるため、マシンが再度確認するまでにかかる最大時間は120分です。

Question 64 of 82

Which of the following is a serial-based protocol?

- ☐ HART
- ☐ Zigbee
- ☐ 802.11g
- ☐ Bluetooth

全82問中64問目

次のうち、シリアルベースのプロトコルはどれですか？

☒ ハート
59712396-1bec-4f78-9e4b-ad14167339a6 (14232745)

- ☐ ジグビー
- ☐ 802.11g
- ☐ ブルートゥース

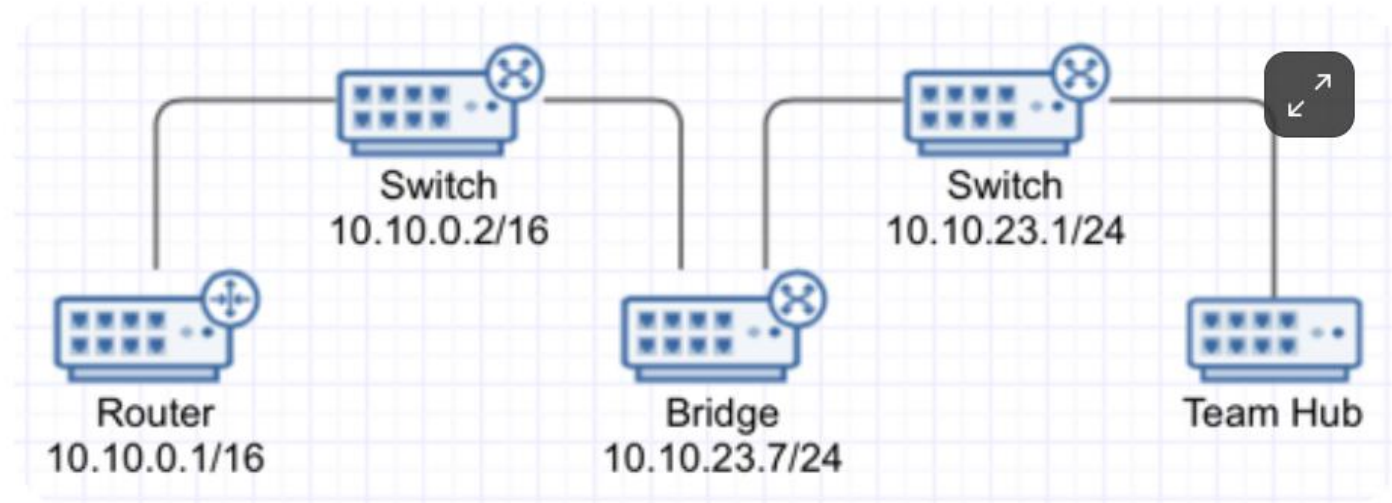
☒ その通りです

WirelessHARTは、HART（Highway Addressable Remote Transducer Protocol）と呼ばれる既存のネットワークプロトコルに基づいています。HARTは、Modbusと同様にシリアル通信をベースとしたプロトコルで、一般的に4-20mAのアナログ回路で使用されます。

Zigbee、802.11g、Bluetoothは無線プロトコルです。

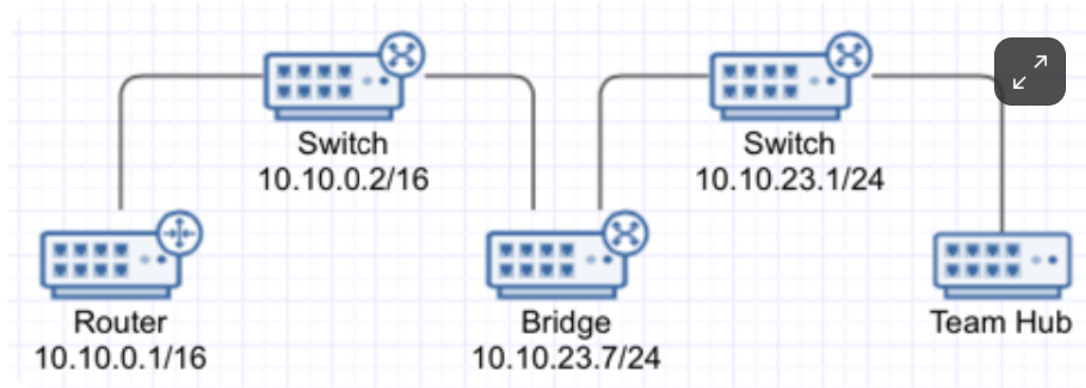
Question 65 of 82

Observe the devices below; which network device will drop Layer 2 broadcast traffic?



- ☐ Switch
- ☐ Hub
- ☐ Bridge
- ☐ Router

以下のデバイスを観察してください。どのネットワークデバイスがレイヤ2ブロードキャストトラフィックをドロップしますか？



- ☐ スイッチ
- ☐ ハブ
- ☒ 橋
- ☒ ルーター

✖ あなたは間違っています

ルーターはレイヤー3で動作し、パケット転送時にIPアドレスを参照します。ルーターはデフォルトではMACレベル（レイヤー2）のトラフィックをすべて破棄します。スイッチとブリッジはMACレベルの情報を使用してトラフィックを切り替えます。ハブは、1つのポートで受信したトラフィックを、稼働中のすべてのポートに単純に中継します。

Question 66 of 82

What is one item that an SIS is designed to protect?

- ☐ The environment
- ☐ Software
- ☐ The process
- ☐ Equipment

全82問中66問目

SISが保護するように設計されているアイテムの1つは何ですか？

5971b396-1b2c-4f78-9e4b-ad14167339a6 (14232745)

- ☒ 環境
- ☐ ソフトウェア
- ☐ そのプロセス
- ☒ 装置

✕ あなたは間違っています

安全計装システム（SIS）は、安全、健康、環境への悪影響を防ぐように設計されています。SISは、安全、健康、環境を保護するために、機器やソフトウェアに関係なくプロセスを停止します。ボパール災害のようなICS事象において、環境が安全と健康に直接どのような影響を与えるかを考えてみてください。

Question 67 of 82

Which of the following is a concern with VSAT communication?

- ☐ Severe weather conditions
- ☐ Lack of VPN support
- ☐ Fixed frequency range
- ☐ Distance of communication

全82問中67問目

VSAT通信に関して懸念される点は次のうちどれですか？

5977b39b-1bce-4f78-9e4b-ad14167339a6 (14232745)



悪天候



VPNサポートの欠如



固定周波数範囲



コミュニケーションの距離



その通りです

VSAT（超小型開口端末）は、複数の周波数帯域で動作できます。VSATリンクは、仮想ローカルエリアネットワーク/プライベートネットワークとデータ暗号化（SSL、SSH、PGPなど）をサポートします。VSATアンテナは、中継衛星との適切な位置とアライメントを維持する必要があり、遮るもののない空の視界が必要となるため、悪天候などの物理的な危険が懸念されます。雨や雪などの悪天候下で送受信を行う必要がある場合、RFリンクは劣化します。VSATは、Cバンド（4～8GHz）、Kuバンド（12～18GHz）、Kaバンド（26.5～40GHz）など、複数の周波数帯域で動作できます。

Question 68 of 82

In a typical ICS architecture, Purdue Level 3 would include which of the following functions?

- ☐ Web facing servers and Simple Mail Transfer Protocol servers
- ☐ Web facing application servers and database servers
- ☐ Application firewalls and data guard technology
- ☐ Patch management servers and site-specific application servers

全82問中68問目

一般的なICSアーキテクチャにおいて、パーデューレベル3には次のうちの機能が含まれるでしょうか？

- 59710396-1bec-4178-9e4b-ad14107359a6 (14232743)
- ☒ **ウェブサーバーとシンプルメール転送プロトコルサーバー**
 - ☐ Web向けアプリケーションサーバーとデータベースサーバー
 - ☐ アプリケーションファイアウォールとデータガード技術
 - ☒ **パッチ管理サーバーおよびサイト固有のアプリケーションサーバー**

☒ あなたは間違っています

レベル3 DMZは、インターネットDMZとは異なります。レベル3 DMZには、サービスやデータをゾーン間で共有できる機能固有のゾーンが含まれます。このゾーンに通常含まれるものには、パッチ管理サーバー、ウイルス対策管理システム、サイト固有のアプリケーションサーバー、ジャンプホスト環境、ビジネスインテリジェンスシステム、サイト固有のアプリケーションのバックエンドデータベース、開発システムなどがあります。このゾーンには、Webに面するものは含まれず、また、エンフォースメントゾーンに配置されるアプリケーションファイアウォールやデータガード技術も含まれません。

Question 69 of 82

Which of the following is the term that describes the process condition where a hazardous safety, health, and environmental event cannot occur?

- ☐ Restore mode
- ☐ Safe state
- ☐ Recovery mode
- ☐ Fail state
- ☐ Ready state

全82問中69問目

危険な安全、健康、環境事象が発生しないプロセス状態を表す用語は、次のうちどれですか？

- ☐ 復元モード
- ☒ 安全な状態
- ☐ リカバリーモード
- ☐ 障害状態
- ☐ 準備完了状態

✓ その通りです

安全計装システム（SIS）は、特に重要なプロセスシステムで使用する、設計されたハードウェアとソフトウェアの制御システムから構成されます。重要なプロセスシステムとは、稼働中に運用上の問題が発生した場合、安全、健康、環境（SH&E）への悪影響を回避するために、システムを安全な状態にする必要があるシステムを指します。

安全状態とは、プロセスが稼働中か停止中かを問わず、危険な安全衛生環境事象が発生しないようなプロセス状態のことです。安全状態は、適切な時期に、すなわち「プロセス安全時間」内に達成されなければなりません。

Question 70 of 82

A security engineer is testing for SQLi vulnerabilities against an internal web application. They fill out the username field with a single quote (') and the password field with random characters. Which response would confirm to the engineer that the SQLi vulnerability is present?

- ☐ The client browser returns an "invalid username" error
- ☐ Authentication to database server is unsuccessful
- ☐ The client web browser returns the password in plaintext
- ☐ SQL error message from the backend database

全82問中70問目

セキュリティエンジニアが、社内Webアプリケーションに対してSQLインジェクションの脆弱性をテストしています。ユーザー名フィールドにはシングルクォーテーション (') を、パスワードフィールドにはランダムな文字を入力します。どの応答が、SQLインジェクションの脆弱性が存在することをエンジニアに確認させるでしょうか？

☒ クライアントブラウザは「無効なユーザー名」エラーを返します

☐ データベースサーバーへの認証に失敗しました

☐ クライアントのウェブブラウザはパスワードを平文で返します

☒ バックエンドデータベースからのSQLエラーメッセージ

☒ あなたは間違っています

SQLインジェクションとは、攻撃者がデータベースコマンド（SQLクエリ言語）を入力欄に挿入し、バックエンドデータベースにそのコマンドを実行させることができる脆弱性です。基本的なSQLインジェクションの脆弱性を検出する最も簡単な方法の一つは、入力欄にシングルクォーテーションを入力し、SQLエラーメッセージが返されるかどうかを確認することです。バックエンドデータベースからSQLエラーメッセージが返されれば、脆弱性が存在することが確認できます。

Question 71 of 82

A Remote Terminal Unit performs what function?

- ☐ It is a electronic device that interfaces field objects with control or SCADA systems
- ☐ It is a wireless device used to capture and forward IP packets within a mesh network
- ☐ It is a protected instrument system designed to initiate shutdown on a fail safe condition

全82問中71問目

リモート端末装置（RTU）はどのような機能を果たしますか？

☒ これは、現場の物体と制御システムまたはSCADAシステムを接続する電子機器です。

☐ これは、メッシュネットワーク内でIPパケットをキャプチャして転送するために使用される無線デバイスです。

☐ これは、フェイルセーフ状態時にシャットダウンを開始するように設計された保護された計装システムです。

☒ その通りです

リモートターミナルユニット（RTU）は、マイクロプロセッサで制御される電子機器であり、現場にある機器と分散制御システムまたはSCADA（監視制御およびデータ収集）システムとを接続する役割を果たす。

Question 72 of 82

According to the DHS suggested patch decision tree, what should a security team do after it is determined that a vulnerability affects their ICS?

- ☐ Analyze the impact to the business needs and operations
- ☐ Analyze the vulnerability footprint
- ☐ Determine if there is a work-around available
- ☐ Determine if the operational needs are greater than the risk

全82問中72問目

国土安全保障省が提案するパッチ適用決定ツリーによると、セキュリティチームは脆弱性が産業制御システム（ICS）に影響を与えることが判明した場合、どのような対応を取るべきでしょうか？

- ☐ ビジネスニーズと業務への影響を分析する
- ☐ 脆弱性の痕跡を分析する
- ☒ 回避策があるかどうかを確認する
- ☒ 運用上のニーズがリスクを上回るかどうかを判断する

✕ あなたは間違っています

チームは、脆弱性がICSに影響を与えるかどうかを判断する必要があります。影響がない場合は、通常どおり運用を継続できますが、影響がある場合は、回避策が利用可能かどうかを判断する必要があります。回避策が利用可能な場合は、予定されているアップデート期間が利用可能になるまで、その回避策を使用できます。回避策がない場合は、運用上のニーズがリスクよりも大きいかどうかをチームが判断する必要があります。この判断には、ビジネスニーズと運用への影響、および脆弱性のフットプリントを分析する必要があります（脆弱性がICSに影響を与えるかどうかを判断した後の2つの判断）。

Question 73 of 82

Which of the following factors increases the system call efficiency of a real-time operating system?

- ☐ The kernel and user space is not likely to be separated
- ☐ The system denies hardware interrupts
- ☐ The OS is embedded
- ☐ The platform is solid state

全82問中73問目

リアルタイムオペレーティングシステムのシステムコール効率を高める要因は次のうちどれですか？

- ☒ カーネル空間とユーザー空間は分離されない可能性が高い
- ☒ システムはハードウェア割り込みを拒否します
- ☐ OSは組み込まれています
- ☐ プラットフォームはソリッドステートです

☒ あなたは間違っています

RTOS上で動作するプロセスは、システムコール効率が高く、割り込みを無効化したり、その他の方法で環境を管理したりすることができます。これは、RTOSシステムではカーネル空間とユーザー空間が分離されていないためです。RTOSではハードウェア割り込みが禁止されているわけではなく、実際にはハードウェア割り込みの処理はRTOSの重要な機能です。システムが組み込みシステムであるという事実だけでは、システムコール効率が必ずしも向上するわけではありません。むしろ、組み込みシステムでRTOSを使用することによって、システムコール効率が向上するのです。

全82問中74問目

延長サポートが終了したMicrosoftオペレーティングシステムを実行しているシステムを保護するために推奨される対策は何ですか？

- ☐ セキュリティ修正プログラムがリリースされたら、購入して適用してください。
- ☐ 自動パッチアップデートを提供する
- ☐ OSのエンタープライズ版に移行する
- ☒ システムを論理的に分離する

✓ その通りです

OSの延長サポート期間が終了し、代替OSが利用できない場合、マイクロソフトはOSを隔離することを推奨しています。延長サポート期間が終了したOSでは、その他のオプションはすべて利用できません。

Question 75 of 82

Which of the following is most effective in ensuring one way data communication from the control system network to a data historian?

- ☐ Data diodes
- ☐ Data concentrator
- ☐ Routers
- ☐ Switch port security

全82問中75問目

制御システムネットワークからデータヒストリアンへの一方向データ通信を確実にするために、次のうちどれが最も効果的ですか？

- ☒ データダイオード
- ☐ データコンセントレータ
- ☐ ルーター
- ☐ スイッチポートのセキュリティ

☒ その通りです

データダイオードは、一方向のデータ通信経路を提供します。データコンセントレータ、ルータ、およびスイッチポートのセキュリティはすべて、それぞれがサポートする通信経路におけるトラフィックの送受信をサポートします。

Question 76 of 82

Use diff to compare the doctor_john and professor_longhair text files located in the GIAC directory on the Desktop. What is different in the two files?

[View VM](#)

- ☐ Added '@'
- ☐ Added '!'
- ☐ Added '%'
- ☐ Missing '+'
- ☐ Added ']'
- ☐ Missing '-'
- ☐ Added '\$'
- ☐ Missing '#'
- ☐ Missing '*'
- ☐ Missing ':'

全82問中76問目

デスクトップ上のGIACディレクトリにあるdoctor_johnとprofessor_longhairという2つのテキストファイルをdiffコマンドで比較してください。2つのファイルの違いは何ですか？

- ☐ 追加した '@'
- ☐ 追加した '!'
- ☐ 追加した '%'
- ☐ 「+」がありません
- ☐ 追加した ']'
- ☐ ない '-'
- ☐ '\$'を追加しました
- ☒ ない '#'
- ☐ ない '*'
- ☒ ない '。'

✖ あなたは間違っています

diff (gc file1) (gc file2)。Windows 版の diff を使用する場合は、gc (get-contents) が必要であることに注意してください。

Question 77 of 82

Examine the control sheet found on the Desktop in the following directory structure:

Velocio PLC\MyChemicalMixer\MyChemicalMixer.vio.

Which of the following is an unsigned 16-bit integer tag?

[View VM](#)

- ☐ Moose
- ☐ Zebra
- ☐ Unicorn
- ☐ Gazelle
- ☐ Seahorse
- ☐ Antelope
- ☐ Bobcat
- ☐ Bear
- ☐ Horse
- ☐ Elk

Exit VM

Reset Environment

Refresh Environment

Exit full screen

Velocio Flow Builder

File Edit Window Tools Help

Setup

Ace 11

Setup Hardware

Solution Logs

MyChemicalMixer

Add Subroutine

C:\Users\student\Desktop\Velocio PLC\MyChemicalMixer\MyChemicalMixer.viof

Start

EmergencyStop

RunProcess

State

Tags

Input / Output	Name	Is Array	Array Size	Used	Remote Writable	Modbus	Delete
Input bit	Bear	☐		☒	☐	☐	
Input i16		☐		☐	☐	☐	
Input Float		☐		☐	☐	☐	
Output bit							
Output ui16							
Register							
bit							
ui8							
i16							
ui16							
i32							
Float							

OK Cancel Help

Errors / Warnings Watch Call Stack Runtime Errors / Warnings

0 Errors 1 Warnings

Number	Description	File	Rung	Row	Column
1	Not linked to anything	MyChemicalMixer.viof	0	25	1

Question 77 of 82

Which of the following is an unsigned 16-bit integer tag?

☐ Moose

☐ Zebra

☐ Unicorn

☐ Gazelle

☐ Seahorse

☐ Antelope

☐ Bobcat

☒ Bear

☐ Horse

☐ Elk

Submit Answer

Need Help?

00:29:19

Note

全82問中77問目

デスクトップにある以下のディレクトリ構造内のコントロールシートを確認してくださいVelocio PLC\MyChemicalMixer\MyChemicalMixer.vio。

次のうち、符号なし16ビット整数タグはどれですか？

☐ ムース

☒ シマウマ

☐ ユニコーン

☐ ガゼル

☐ タツノオトシゴ

☐ アンテロープ

☐ ボブキャット

☒ クマ

☐ 馬

☐ ヘラジカ

☒ あなたは間違っています

Velocioでは、上部のアイコンバーから「タグ」アイコンを選択します。

「ui16」ボタンを選択してください。

Zebraは「ui16」に分類されるため、符号なし整数となります。

Question 78 of 82

Examine packet 19 in meow.pcap (located in the GIAC directory on the Desktop) using Wireshark. What is the last address read?

Note: This packet contains Modbus data.

Unit ID	Read Function	Start Address	Num to Read	CRC
1 byte	1 byte	2 bytes	2 bytes	2 bytes
2 hex chars	2 hex chars	4 hex chars	4 hex chars	4 hex chars

View VM

- ☐ 6
- ☐ 5
- ☐ 1
- ☐ 4
- ☐ 3
- ☐ 8
- ☐ 9
- ☐ 10
- ☐ 2
- ☐ 7

Wiresharkを使用して、デスクトップ上のGIACディレクトリにあるmeow.pcapファイル内のパケット19を調べてください。最後に読み取られたアドレスは何ですか？

注：このパケットにはModbusデータが含まれています。

Unit ID	Read Function	Start Address	Num to Read	CRC
1 byte	1 byte	2 bytes	2 bytes	2 bytes
2 hex chars	2 hex chars	4 hex chars	4 hex chars	4 hex chars

- ☐ 6
59712390fbec-4f78-9e4b-ad14167339a6 (14232745)
- ☐ 5
- ☐ 1
- ☐ 4
- ☐ 3
- ☐ 8
- ☒ 9
- ☐ 10
- ☒ 2
- ☐ 7

✖ あなたは間違っています

ここでのModbusデータは0x010100060004ddc8です。

0x0006は最初に読み取られたアドレスであり、0x0004は読み取られたアドレスの数なので、0x0009は最後に読み取られたアドレスになります。

Question 79 of 82

Open Firefox, navigate to localhost, and click on "Login" under the Main Menu on the left side of the page. The "Name:" field is vulnerable to SQL injection. Use SQL injection to log in as the user coltrane. What are the three words that are now displayed near the top of the left hand column?

HINT: Spaces before *and after* SQL comments are required. Also be sure to enter at least one character in the password field.

[View VM](#)

- ☐ Treaty, Blackmail, Impress
- ☐ Feather, Jewel, Command
- ☐ Virtue, Chapter, Divide
- ☐ Response, Presense, Extent
- ☐ Onion, Pumpkin, Gallon
- ☐ Reform, Training, Access
- ☐ Coffee, Humor, Outlook
- ☐ Mobile, Steward, Muscle
- ☐ Diet, Reward, Knowledge
- ☐ Stable, Future, Moral

Exit VM

Reset Environment

Refresh Environment

Activities

Firefox ESR

May 9 22:08

Exit full screen

Home

Trash

Downloads

Samples

GIAC

dead.letter

Florence Virtual Keyboard

Terminal

Dojo-Control Home

Dojo-Control Home

localhost/index.php

Welcome to Dojo Control's Shift Logger!

You are logged in as coltrane

Main Menu

[Home](#)

Response

Presense

Extent

[User Info](#)

[Enter Shift Log](#)

[View Shift Logs](#)

[Reading Room](#)

[Play Snake](#)

[Logout](#)

User Utilities

[Ping Asset](#)

[DNS Lookup](#)

[Browser Info](#)

Pentester Help

Dojo Control

Here at Dojo Control Industries we pride ourselves on the quality and quantity of the products that we make and sell. We have been doing business since 1976, and are in over 30 different countries.

Our CEO, Kevin Flynn is second to none when it comes to eliminating his rivals. He is the hand and you are the weapon. Keep yourself sharp!

If you are a new operator, please use the links to the left to register a new account.

Question 79 of 82

comments are required. Also be sure to enter at least one character in the password field.

☐ Treaty, Blackmail, Impress

☐ Feather, Jewel, Command

☐ Virtue, Chapter, Divide

☒ Response, Presense, Extent

☐ Onion, Pumpkin, Gallon

☐ Reform, Training, Access

☐ Coffee, Humor, Outlook

☐ Mobile, Steward, Muscle

☐ Diet, Reward, Knowledge

☐ Stable, Future, Moral

Submit Answer

Need Help?

00:20:18

全82問中79問目

Firefoxを開き、localhostにアクセスして、ページの左側にあるメインメニューの「ログイン」をクリックします。「名前:」フィールドはSQLインジェクションの脆弱性があります。SQLインジェクションを使用して、ユーザーcoltraneとしてログインしてください。左側の列の上部付近に表示される3つの単語は何ですか？

ヒント：SQLコメントの前後にはスペースが必要です。また、パスワード欄には少なくとも1文字を入力してください。

- ☐ 条約、脅迫、強制
- ☐ 羽根、宝石、命令
- ☐ 美德、章、分割
- ☒ 反応、存在、範囲
- ☐ 玉ねぎ、かぼちゃ、ガロン
- ☐ 改革、研修、アクセス
- ☐ コーヒー、ユーモア、展望
- ☐ モバイル、スチュワード、マッスル
- ☐ 食事、報酬、知識
- ☐ 安定、未来、道徳

✔ その通りです

名前欄に名前を入力しcoltrane' -- 、パスワード欄には任意の文字列を入力してください。すると、魔法の言葉が表示されます。

Question 80 of 82

Examine ~/GIAC/plantemonium.pcap using Wireshark. Which value is in the "Length" column for the packet associated with function code 17?

[View VM](#)

- ☐ 69
- ☐ 64
- ☐ 98
- ☐ 66
- ☐ 92
- ☐ 95
- ☐ 94
- ☐ 62
- ☐ 68
- ☐ 97

plantemonium.pcap

FileEditViewGoCaptureAnalyzeStatisticsTelephonyWirelessToolsHelp

modbus.func_code == 17

No.	Time	Source	Destination	Length	Leftover Capture Data	Info
66...	153989.793828	10.21.2...	10.21.22.23	62		unknown: Trans: 0; Unit: 1, Func: 17: Report Slave ID. Unable to classify as query or response.

Frame 6679: 62 bytes on wire (496 bits), 62 bytes captured (496 bits)

Ethernet II, Src: VMware_f7:f4:9a (00:0c:29:f7:f4:9a), Dst: SecretLa_00:6c:02 (5c:86:4a:00:6c:02)

Internet Protocol Version 4, Src: 10.21.22.253, Dst: 10.21.22.23

Transmission Control Protocol, Src Port: 46139, Dst Port: 502, Seq: 1, Ack: 1, Len: 8

Modbus/TCP

Modbus

00005c 86 4a 00 6c 02 00 0c 29 f7 f4 9a 08 00 45 00 \.J.L...)....E.

001000 30 e1 8e 40 00 40 06 17 fc 0a 15 16 fd 0a 15 .0..@.@.....

002016 17 b4 3b 01 f6 69 0f 7e dd 60 45 24 52 50 18 ...;..i. ~`E\$RP.

Rescanning: plantemonium.pcap

Filtering modbus.func_code == 17

Packets: 170574 · Displayed: 170574 (100.0%)

Profile: Default

Question 80 of 82

using Wireshark. Which value is in the "Length" column for the packet associated with function code 17?

☐ 69

☐ 64

☐ 98

☐ 66

☐ 92

☐ 95

☐ 94

☒ 62

☐ 68

☐ 97

Submit Answer

Need Help?

00:16:39

全82問中80問目

Wiresharkを使用して~/GIAC/plantemonium.pcapを調べます。機能コード17に関連付けられたパケットの「長さ」列にはどの値が表示されますか？

- ☐ 69
- ☐ 64
- ☐ 98
- ☐ 66
- ☐ 92
- ☐ 95
- ☐ 94
- ☒ 62
- ☐ 68
- ☐ 97

✓ その通りです

表示フィルターを使用して`modbus.func_code == 17`この答えを見つけてください。

Question 81 of 82

What are the last four digits of the hash created when using openssl with the sha3-512 digest on ~/GIAC/film?

[View VM](#)

- ☐ 3b2e
- ☐ 8c6b
- ☐ 24d7
- ☐ 32e0
- ☐ e0af
- ☐ 099c
- ☐ a77f
- ☐ 8b02
- ☐ 472b
- ☐ 1d50


```
Terminal
echo -n Rashomon > plaintext
ls
ct-cyberchef.desktop  org.gnome.Calculator.desktop
dead.letter          org.gnome.Terminal.desktop
Downloads             org.wireshark.Wireshark.desktop
firefox-esr.desktop  plaintext
florence.desktop     Samples
GIAC

cat plaintext
Rashomon%

openssl dgst -sha3-512 plaintext
SHA3-512(plaintext)= a439b8cd88ebb9d3f04bbfd74f5e4155e76c79f8d04a52cf2bbe430cea00efde95d325fec8c5a123e8ec82ded35a9f8265533389b853d51a5c5708dff39a77f
```

dead.letter

plaintext

- Keccak
- RIPEMD
- HAS-160
- Snefru
- Entropy
- Generate TOTP
- Generate HOTP

Bake!

Step Clear breakpoints

Save recipe Load recipe Clear recipe

cyberChef

SHA3('512')&input=UmFzaG9tb24

Input

Rashomon

Output

a439b8cd88ebb9d3f04bbfd74f5e4155e76c79f8d04a52cf2bbe430cea00efde95d325fec8c5a123e8ec82ded35a9f8265533389b853d51a5c5708dff39a77f

Question 81 of 82

What are the last four digits of the hash created when using openssl with the sha3-512 digest on ~/GIAC/film?

- ☐ 3b2e
- ☐ 8c6b
- ☐ 24d7
- ☐ 32e0
- ☐ e0af
- ☐ 099c
- ☒ a77f
- ☐ 8b02
- ☐ 472b
- ☐ 1d50

Submit Answer

Need Help?

00:08:54

全82問中81問目

~/GIAC/film に対して openssl を sha3-512 ダイジェストで使した場合に生成されるハッシュの最後の4桁は何ですか？

- 59712390-1bec-4f78-9e4b-ad14167339a6 (14232745)
- ☐ 3b2e
 - ☐ 8c6b
 - ☐ 24日7日
 - ☐ 32e0
 - ☐ e0af
 - ☐ 099c
 - ☒ a77f
 - ☐ 8b02
 - ☐ 472b
 - ☐ 1d50

✓ その通りです

この結果を得るには、コマンドラインでopensslを使用するか、CyberChef（ターミナルから起動）を使用してください。

オプション: dgst -sha3-512

Question 82 of 82

Examine ~/GIAC/memdump/dump2. At which offset is mbiter.h referenced?

Hint: Try piping to **grep** to minimize output.

[View VM](#)

- ☐ 259b
- ☐ 4600
- ☐ 1aec
- ☐ 1f0e
- ☐ 8ce0
- ☐ 0bc1
- ☐ 965d
- ☐ 20fc
- ☐ 0e12
- ☐ 7ee5

Activities

Terminal

Terminal

~ /GIAC/memdump

✓ (at 22:21:36)

```
xxd dump2 | grep mbiter.h
00008ce0: 0000 0000 6d62 6974 6572 2e68 006d 6269  ....mbiter.h.mbi
```

~ /GIAC/memdump

✓ (at 22:22:05)

May 9 22:22

Terminal

film
~/GIAC

Save

Home

GIAC

memdump

dump

dump2

raw_key_10

raw_key_13

Other Locations

dead.letter

plaintext

Plain Text

Tab Width: 8

Ln 1, Col 9

INS

全82問中82問目

~/GIAC/memdump/dump2を調べてください。mbiter.hはどのオフセットで参照されていますか？

ヒント：grep出力を最小限に抑えるために、パイプ処理を試してみてください。

☐ 259b

☐ 4600

☐ 1aec

☐ 1f0e

☐ 8ce0

☐ 0bc1

☐ 965d

☐ 70fr

回答を送信

お困りですか？

00:06:06

全82問中82問目

~/GIAC/memdump/dump2 を調べてください。mbiter.h はどのオフセットで参照されていますか？

ヒント：**grep**出力を最小限に抑えるために、パイプ処理を試してみてください。

- ☐ 259b
- ☐ 4600
- ☐ 1aec
- ☐ 1f0e
- ☒ **8ce0**
- ☐ 0bc1
- ☐ 965d
- ☐ 20fc
- ☐ 0e12
- ☐ 7ee5

✓ その通りです

xxd は、データの ASCII 表現と、データが見つかったオフセットを出力します。

終了しました

練習 失敗

スコア：60 %（不合格）



GICSP模擬試験

試験問題

合計：82

回答済み：82

ステータス：**失敗**

あなたのスコア：60 %

最低合格点：71 %

完了日：2026年5月10日

CyberLive認証バイパス



CyberLiveバイナリファイル解析



サイバーライブ暗号化



CyberLiveエンドポイントのセキュリティ強化、ベースライン、ログ



CyberLiveフィールドバスプロトコル分析



CyberLive産業交通分析



エンドポイントの強化と保護



ICSコンポーネントとアーキテクチャ



ICSの概要と概念



ICSプログラムおよび政策開発



情報収集と脅威モデリング



PERAレベル0および1の技術概要と侵害



PERAレベル2および3の技術概要とリスク



プロトコル、コミュニケーション、そして妥協



リスクベースの災害復旧およびインシデント対応



無線技術とその限界

